

Informe de Situación Actual - Comunicaciones, Networking y Seguridad Perimetral

Real Casa de la Moneda

Fábrica Nacional de Moneda y Timbre

Consultoría para el rediseño de la infraestructura FNMT-RCM (CERES)

02 diciembre 2025 | Versión 1.1

Contenido

1.	Introducción	8
1.1.	Objetivo y audiencia	8
1.2.	Alcance	8
1.3.	Metodología	9
2.	Descripción de la infraestructura.....	11
2.1.	Arquitectura de red (topología, segmentación L2 Y L3, enrutamiento)	11
2.2.	Líneas de Comunicaciones y Accesos Externos	12
2.2.1	Salida a Internet	12
2.2.2	Accesos externos	12
2.2.3	Líneas Inter-centro de datos	13
2.2.4	Capa física	14
2.2.5	Capa lógica	15
2.2.6	Hardware implementado	16
2.2.7	Direccionamiento IP	18
2.2.8	Publicación y acceso a servicios (Akamai, Red SARA).....	20
2.2.9	Balanceo de carga (F5 BIG IP)	22
2.2.10	Seguridad (Firewalls, segmentación interna, WAF, DDoS)	23
2.2.11	DNS (Servicio de nombres, interno y externo)	24
2.3.	Políticas operativas de gestión	26
2.3.1	Gestión de la Red.....	26
2.3.2	Gestión de la Seguridad.....	26
3.	Matriz de riesgos	30
3.1.	Resumen de riesgos agrupados por nivel de riesgo	32
3.2.	Top de riesgos	32
4.	Niveles de Madurez	34
4.1.	Metodología de valoración y lectura de resultados	34
4.2.	Evaluación de la madurez de Comunicaciones, Redes y Seguridad perimetral.....	35
4.2.1	Red de Centro de Datos y LAN corporativa.....	35
4.2.2	WAN y conectividad externa	35
4.2.3	Seguridad perimetral y control de acceso	36
4.2.4	Servicios de red y direccionamiento (DDI).....	36
4.2.5	Observabilidad, operación y continuidad	37
4.2.6	Notas de interpretación y cierre	37
5.	Conclusiones.....	38
5.1.	Arquitectura de red.....	38
5.2.	Balanceo de carga	38
5.3.	Seguridad y segmentación	38

5.4.	Gestión operativa y seguridad	39
5.5.	Políticas de gestión y operación	39
5.6.	DNS	39
5.7.	Resumen global	39

Lista de abreviaturas

Abreviaturas	Significado
802.1X	Estándar IEEE para control de acceso a red (NAC).
ACL	Access Control List, lista de control de acceso.
AD	Active Directory, servicio de directorio.
ADC	Application Delivery Controller, controlador de entrega de aplicaciones.
ALH	Auto Last Hop, funcionalidad de F5 para mantener la simetría de retorno.
ANS	Acuerdo de Nivel de Servicio.
App-ID	Identificación de aplicaciones en NGFW (Palo Alto).
AS	Autonomous System, sistema autónomo de Internet.
AS-IS	Situación actual, "tal cual".
BGP	Border Gateway Protocol - Protocolo de enrutamiento entre sistemas autónomos.
BIND	Berkeley Internet Name Domain, software de servidor DNS.
CDN	Content Delivery Network, red de distribución de contenidos.
CMDB	Configuration Management DataBase, base de datos de configuración.
CPE	Customer Premises Equipment, equipo de cliente del operador.
CVE	Common Vulnerabilities and Exposures, identificador de vulnerabilidades.
DC	Data Center, centro de datos.
DDI	Conjunto de servicios DNS, DHCP e IPAM.
DDoS	Distributed Denial of Service, denegación de servicio distribuida.
DHCP	Dynamic Host Configuration Protocol.
DMZ	Demilitarized Zone, zona perimetral de publicación.
DNS	Domain Name System, sistema de nombres de dominio.
DNSSEC	Domain Name System Security Extensions, extensiones de seguridad DNS.
DORA	Digital Operational Resilience Act, reglamento europeo de resiliencia digital.
DR	Disaster Recovery, recuperación ante desastres.
DWDM	Dense Wavelength Division Multiplexing - Tecnología óptica de multiplexación por longitudes de onda.
EVPN	Ethernet VPN, overlay de L2 sobre L3 con control BGP.
FW	Firewall.
GSLB	Global Server Load Balancing, balanceo geográfico por DNS.
GUI	Graphical User Interface, interfaz gráfica.

Abreviaturas	Significado
HA	High Availability, alta disponibilidad.
HSRP	Hot Standby Router Protocol - Protocolo de redundancia de gateways.
IaC	Infrastructure as Code, infraestructura como código.
iBGP o eBGP	BGP interno (iBGP) o BGP externo (eBGP) - Variantes de BGP para enrutamiento interno o entre proveedores.
IDS	Intrusion Detection System.
IP	Internet Protocol.
IPAM	IP Address Management, gestión de direcciones IP.
IPFIX	IP Flow Information eXport, exportación de flujos.
IPS	Intrusion Prevention System.
ISP	Internet Service Provider, proveedor de Internet.
KPI	Key Performance Indicator, indicador clave.
L2 Y L3	Layer 2 / Layer 3 - Capas del modelo OSI: conmutación (L2) y enrutamiento (L3).
L4	Capa 4 del modelo OSI, transporte.
L7	Capa 7 del modelo OSI, aplicación.
LACP	Link Aggregation Control Protocol.
LAN	Local Area Network, red de área local.
LB	Load Balancer, balanceador de carga.
MFA	Multi-Factor Authentication, autenticación multifactor.
MPLS	Multiprotocol Label Switching.
NAC	Network Access Control, control de acceso a red.
NAT	Network Address Translation.
NDFC	Nexus Dashboard Fabric Controller (Cisco).
NetFlow	Telemetría de flujos de red (Cisco).
NGFW	Next-Generation Firewall, firewall de nueva generación.
NOC	Network Operations Center.
NTP	Network Time Protocol.
NX-OS	Sistema operativo de switches Cisco Nexus.
OS	Operating System, sistema operativo.
OSI	Open Systems Interconnection, modelo de referencia.
PAM	Privileged Access Management, gestión de accesos privilegiados.

Abreviaturas	Significado
PKI	Public Key Infrastructure, infraestructura de clave pública.
QoS	Quality of Service, calidad de servicio.
RA	Remote Access, acceso remoto.
RADIUS	Remote Authentication Dial-In User Service.
RHEL	Red Hat Enterprise Linux.
ROA	Real Observatorio de la Armada, fuente NTP.
RPO	Recovery Point Objective.
RTO	Recovery Time Objective.
SARA	Red SARA, red privada de la Administración Pública española.
SDN	Software-Defined Networking.
SD-WAN	Software-Defined WAN.
sFlow	Muestreo de flujos de red.
SIEM	Security Information and Event Management.
SLA	Service Level Agreement, acuerdo de nivel de servicio.
SLO	Service Level Objective, objetivo de nivel de servicio.
SOC	Security Operations Center.
TLS	Transport Layer Security.
TO-BE	Estado objetivo.
TO-DO	Plan de acciones.
ToR	Top-of-Rack, switch de borde de rack.
URL	Uniform Resource Locator, dirección web.
VIP	Virtual IP, IP virtual.
VLAN	Virtual LAN.
vPC	Virtual Port Channel - Tecnología de Cisco que permite agregar enlaces físicos entre dispositivos para redundancia.
VRF	Virtual Routing and Forwarding - Mecanismo de virtualización de tablas de enrutamiento.
VRRP	Virtual Router Redundancy Protocol.
VXLAN	Virtual Extensible LAN - Tecnología de virtualización de red de capa 2 sobre capa 3.
WAF	Web Application Firewall - Firewall especializado para proteger aplicaciones web.
WAN	Wide Area Network.

Histórico del Documento

Versión	Fecha	Comentarios	Páginas Afectadas
1.0	17/11/2025	Original	Todas
1.1	02/12/2025	Modificación con mejoras identificadas por el cliente	Apartados 2,3,4 y 5

1. Introducción

1.1. Objetivo y audiencia

Este documento forma parte del conjunto de análisis AS-IS del proyecto CB-52-1631-2025 para el rediseño de la infraestructura de CERES (FNMT-RCM).

Su objetivo es describir, verificar y valorar la situación actual de la torre de Comunicaciones, Redes y Seguridad Perimetral, proporcionando una visión técnica rigurosa de su arquitectura física y lógica, de los mecanismos de redundancia y balanceo, y de los controles de seguridad desplegados.

El análisis aborda tanto la infraestructura de red y comunicaciones inter-CPD como los servicios de acceso externo (Internet, Red SARA, balanceadores, firewalls, WAF y DNS), evaluando su madurez frente a marcos de referencia en resiliencia, continuidad y ciberseguridad.

Con ello, se establecen las bases objetivas que alimentarán el TO-BE (Fase II) y el plan de actuación TO-DO (Fase III) definidos en la metodología del proyecto.

El documento está dirigido a los equipos técnicos de redes, seguridad e infraestructura, así como a las áreas de gobernanza TIC, ciberseguridad y dirección responsables de la toma de decisiones sobre el modelo futuro de red y comunicaciones de CERES.

Complementa el AS-IS general del proyecto con el detalle específico de esta torre tecnológica y sus interdependencias con los dominios de virtualización, almacenamiento, bases de datos y continuidad de servicio.

La elaboración se ha realizado con un enfoque orientado a evidencias, no intrusivo y trazable, bajo los compromisos de confidencialidad y custodia establecidos con la FNMT-RCM. En coherencia con la criticidad de los servicios de certificación electrónica y las lecciones aprendidas tras el incidente del 28 de abril de 2025, las valoraciones priorizan la disponibilidad, la seguridad perimetral, la resiliencia operativa y el cumplimiento regulatorio (ENS Alto, ISO 27001, DORA).

1.2. Alcance

Este AS-IS cubre la situación actual de la torre de Comunicaciones, Redes y Seguridad Perimetral de CERES (FNMT-RCM), incluyendo arquitectura, operación y controles de seguridad asociados. El perímetro del análisis comprende los dos CPD principales (Jorge Juan y TecnoAlcalá) y los enlaces e interconexiones que soportan los servicios críticos de certificación y los sistemas corporativos.

En alcance (qué se evalúa):

- Topología y conectividad: Redes core y distribución, segmentación L2 Y L3, routing dinámico y estático, VLANs, MPLS Y DWDM, enlaces inter-CPD, y conectividad con Red SARA e Internet.
- Servicios de red base: DNS, DHCP, NTP, servicios de directorio para control de acceso de red (p. ej., RADIUS O TACACS+), y NAC (802.1X) donde aplique.
- Redes de acceso y especiales: LAN de CPD, WLAN (si aplica en entornos técnicos), bastionado de acceso remoto y VPN (site-to-site y remoto de administradores y proveedores).
- Seguridad perimetral y publicación de servicios: Firewalls (perimetrales y de inter-zonas), IDS E IPS, WAF, balanceadores de carga y LB, reverse proxy, TLS offloading, DDoS (si aplica) y políticas asociadas.
- Zonificación y control de flujos: Diseño de zonas y DMZ, reglas de microsegmentación, listas de control de acceso, y matriz de comunicaciones entre capas (usuario, app, datos).

- Gestión, operación y observabilidad de red: Herramientas de monitorización (métricas, syslog, NetFlow, IPFIX), gestión de configuración (backups, plantillas), gestión de cambios y procedimientos de capacidad/continuidad de la red.
- Continuidad y resiliencia: Redundancias (equipos, fuentes, enlaces), alta disponibilidad (VRRP O HSRP, clustering), failover inter-CPD, y dependencias con los SLA de operadoras y proveedores.
- Cumplimiento y control interno: Controles y evidencias relevantes respecto a ENS (nivel Alto), ISO/IEC 27001 y buenas prácticas de hardening perimetral.

Fuera de alcance (qué no se evalúa en detalle en este documento):

- Seguridad endpoint, EDR/XDR, hardening de sistemas y gestión de vulnerabilidades a nivel de host (cubierto en otras torres).
- Arquitecturas y plataformas de aplicaciones (APM, middleware, lógica de negocio) salvo su exposición y publicación.
- Procesos SOC/NOC a profundidad (detección, respuesta, threat hunting), salvo interfaces con registros y eventos de red.
- Sistemas internos no relacionados con red (almacenamiento, virtualización, BBDD), analizados en sus documentos específicos.
- Revisión legal de contratos, se consideran únicamente cláusulas técnicas y ANS relacionadas con comunicaciones y perímetro.

Interdependencias con otras torres:

- Virtualización y plataformas (para flujos Este-Oeste y publicación de servicios).
- Almacenamiento y Backup (ventanas de replicación, consumo de ancho de banda, QoS).
- Bases de datos (puertos, latencias requeridas, arquitectura de alta disponibilidad).
- Continuidad y DR (conmutación inter-CPD y pruebas de resiliencia).
- Gobernanza y seguridad (ENS, gestión de cambios, evidencias).

Fuentes de información y evidencias:

- Inventarios y diagramas de red, configuraciones exportadas (sanitizadas), listados de reglas (firewall, WAF y LB), registros syslog y NetFlow, SLA y ANS de operadores y proveedores, y actas de entrevistas.
- Métricas de disponibilidad y capacidad, y alertas históricas de monitorización.

1.3. Metodología

La elaboración de este AS-IS se ha realizado mediante una metodología no intrusiva, orientada a evidencias y reproducible, con foco en la fidelidad técnica del inventario, la verificación cruzada y la trazabilidad de hallazgos. La metodología ha seguido tres movimientos:

1. Levantamiento y contraste mediante entrevistas estructuradas y revisión documental, con emisión de actas para confirmar el entendimiento
2. Modelado del AS-IS, incorporando topologías, flujos y dependencias estrictamente necesarias para comprender la operación.

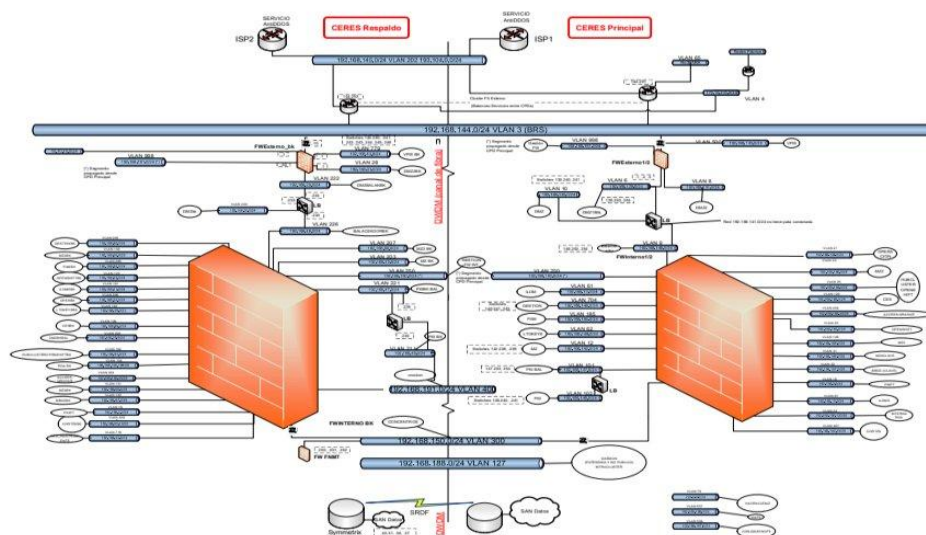
3. Evaluación y síntesis, valorando la madurez frente a buenas prácticas y derivando hallazgos y riesgos que alimentarán el TO-DO y el TO-BE.

La información primaria procede de entrevistas técnicas estructuradas con los responsables de operación y administración de la torre, complementadas con la revisión de documentación proporcionada por la organización y con verificaciones puntuales en consola cuando se dispuso de acceso. La fotografía que se presenta en este documento es la vigente a la fecha de cierre de la fase de entrevistas y recopilación de evidencias.

Todo el trabajo se ha realizado bajo los compromisos de confidencialidad y custodia de la información asumidos con FNMT-RCM (CERES), limitando el detalle operativo a lo estrictamente necesario para la comprensión del AS-IS y evitando la inclusión de credenciales, datos personales u otros elementos sensibles.

2. Descripción de la infraestructura

2.1. Arquitectura de red (topología, segmentación L2 Y L3, enrutamiento)



La arquitectura de red actual de FNMT-RCM (CERES) sigue un esquema **dual** con dos centros de datos geográficamente separados: un CPD principal en la sede de Madrid (Jorge Juan) y un CPD secundario o de respaldo en otra ubicación de Madrid. En la Figura 1 se ilustra la arquitectura lógica a alto nivel. Cada CPD cuenta con su propia infraestructura de switching, routing y seguridad perimetral, estando ambos integrados mediante enlaces de alta capacidad.

El funcionamiento actual de los dos CPDs es activo-pasivo. Aunque se pueda considerar que se puede repartir la carga entre los dos Centro de datos simultáneamente y así hacer que los dos puedan gestionar datos, se considera que hay elementos únicos por los que fluye todo el tráfico. Para considerar el funcionamiento como activo/activo debería haber mucha más independencia entre los CPDs.

Por otro lado, nos encontramos con los equipos que hay en cada CPD. En la actualidad no existen el mismo número en cada CPD. En el CPD principal todos los equipos están funcionando por parejas en HA, mientras que en el CPD de respaldo sólo existe un miembro funcionado en modo standalone, por lo que el nivel de resiliencia ya no es el mismo.

En cuanto a los entornos, también nos encontramos con diferencias. Está el entorno de PRO por un lado y el entorno de PRE/Desarrollo. A nivel lógico pretenden simular el mismo entorno, pero a nivel físico no constan de los mismos elementos, incluso algunos elementos son fabricantes diferentes.

El protocolo de routing utilizado en el CPD es estático, excepto en la parte de la salida a Internet que los operadores utilizan BGP para publicar el AS de FNMT-RCM (CERES).

```

route: 193.104.0.0/24
descr: FABRICA-NACIONAL-DE-MONEDA-Y-TIMBRE
origin: AS41072
mnt-by: FNMT
mnt-by: MAINT-AS3352
created: 2013-04-16T13:04:05Z
last-modified: 2025-09-22T14:59:02Z
source: RIPE# Filtered

```

2.2. Líneas de Comunicaciones y Accesos Externos

2.2.1 Salida a Internet

La salida a Internet de los CPDs es a través de COLT en CPD de respaldo y Telefonica en CPD principal. Cada CPD dispone de dos routers perimetrales (uno por operador: Telefónica y COLT). HSRP se configura por CPD sobre la VLAN de egress. En la práctica, los F5 utilizan la VIP de HSRP como gateway por defecto para el tráfico que se origina en los CPDs, mientras que para el tráfico de retorno de peticiones entrantes se apoya principalmente en la funcionalidad Auto Last Hop.

En cuanto a los enlaces que ofrecen conectividad a Internet, por un lado, está COLT en el CPD de Respaldo que tiene un ancho de banda de 2Gbps y en el CPD principal 1Gbps con Telefónica. La ampliación a 2Gbps en el CPD principal está ya contratada y en proceso de implementación, en previsión del incremento de consumo asociado, entre otros, al servicio de video identificación.

Se ha revisado el documento de capacidad y se observa que los consumos de las líneas de Internet están sobre los 400-600 Mbps, aproximadamente el 60% de utilización.

Respecto a los **flujos de tráfico de Internet**, se ha detectado lo siguiente:

- **Tráfico de entrada:** Aunque existe multihoming con dos operadores, en la práctica la mayor parte del tráfico entra por un único upstream (CPE). No se emplea GSLB para reparto DNS
- **Tráfico de salida:** Hay un HSRP entre los 4 routers de operadora. Los F5 externos tienen como gateway la IP de HSRP y el tráfico saliente hacia Internet se enruta a través del router que ostenta el rol activo en cada momento, concentrando así la salida efectiva en dicho equipo. En este clúster de F5 también se utiliza la característica "Auto Last Hop" mencionada anteriormente, de forma que para el tráfico de entrada se devuelve la respuesta por el mismo router por el que llegó el flujo, conservando así la simetría de retorno y aumentando la resiliencia.

2.2.2 Accesos externos

Se han identificado los siguientes accesos externos:

- Entrada/salida de Internet comentado anteriormente.
- La red de Fábrica: Conectividad con los diferentes departamentos de FNMT-RCM (CERES).
- Red SARA: Conectividad con los diferentes organismos públicos, a través de la interconexión entre los CPDs de FNMT y CERES, actualmente resuelta mediante extensión con cables de cobre y con un plan en marcha para sustituirlos por una extensión de dos enlaces de fibra en PortChannel.
- Conectividad con el Real Observatorio de la Armada: Se utiliza para la sincronización NTP.

El dispositivo de L3 gestionado por FNMT-RCM (CERES), por el que entran estos accesos es el clúster de balanceadores F5 externos.

El acceso a la red SARA se ofrece a través de 4 routers, ubicados dos en cada CPD y configurados en activo-pasivo/pasivo/pasivo. Un punto de fallo detectado en esta conectividad es que la comunicación de estos equipos en la red de CERES se realiza mediante una extensión de L2 entre los dos CPD y los del CPD principal conectados a la red de Fábrica. Por lo tanto, un problema en los switches de Fábrica afectaría a la red de SARA.

La red administrativa SARA (para interconexión con organismos públicos) opera normalmente con menos de ~100 Mbps de tráfico y podría escalarse aproximadamente a 1 Gbps según las previsiones.

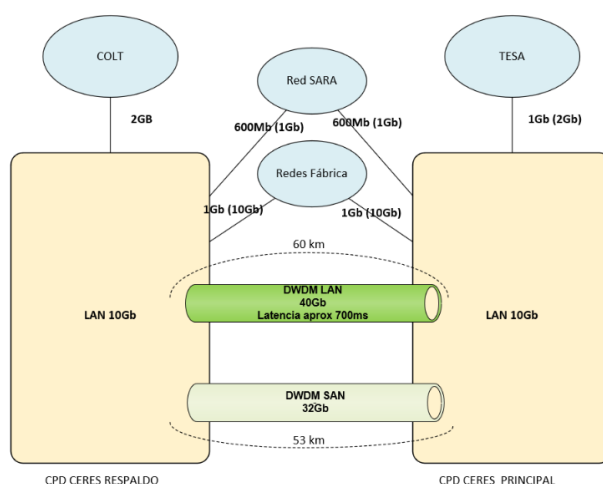
La única área identificada con posible limitación es la red de la Fábrica (red local que interconecta los sistemas internos de FNMT-RCM (CERES) fuera del CPD), actualmente de 1 Gbps, la cual se tiene planificado migrar a 10 Gbps para alinearla con el resto de la infraestructura de alta velocidad.

2.2.3 Líneas Inter-centro de datos

Los CPDs principal y respaldo están interconectados mediante dos fibras oscuras dedicadas, operando con tecnología DWDM, lo que permite multiplexar múltiples canales (segmentados para tráfico LAN y para replicación SAN de almacenamiento) sobre cada fibra.

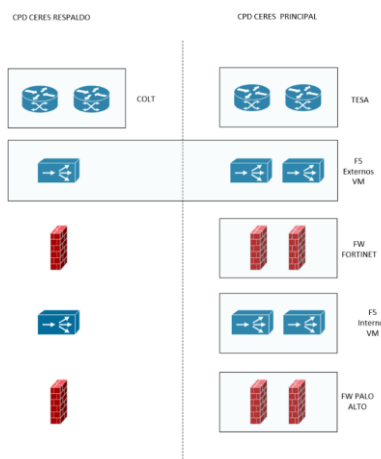
Estas fibras siguen trayectos físicos diversificados, de forma que constituyen rutas independientes entre los sitios, asegurando la continuidad de la conectividad incluso ante la rotura de una de ellas.

Actualmente los enlaces DWDM proporcionan una capacidad de 100Gbps, de la cual se han reservado 40Gbps para tráfico Ethernet (LAN) y 64Gbps para tráfico Fibre Channel (SAN). La latencia aproximada que ofrecen estos enlaces es de unos 0,7 ms. El actual consumo de estos enlaces aún está muy lejos de ser motivo de preocupación y es la adecuada para las necesidades actuales.



2.2.4 Capa física

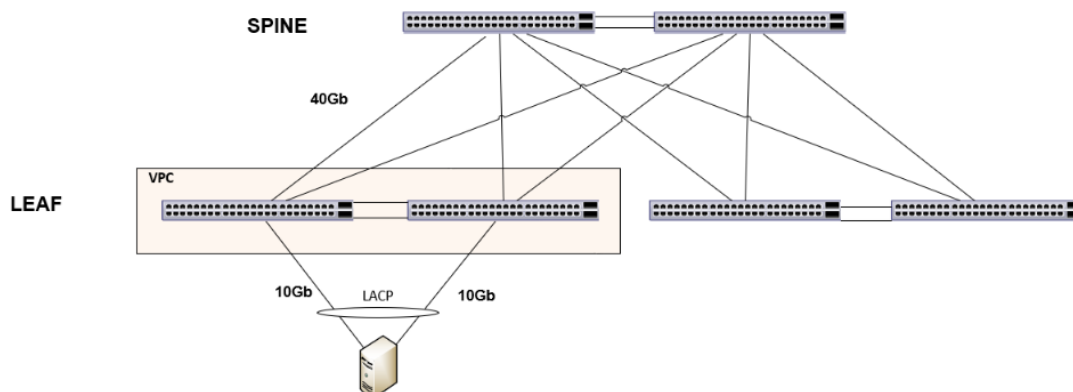
Respecto a la capa física, tal y como ya hemos comentado anteriormente en el CPD principal los dispositivos están en HA y en el CPD de respaldo en modo standalone. En el caso concreto de los routers de proveedor, forman en conjunto un grupo HSRP en la LAN interna y establecen sesiones BGP en modo activo/activo/activo/activo con los operadores, lo que permite aprovechar de forma simultánea los cuatro equipos.



En la siguiente figura se puede observar cómo los equipos que están dentro del mismo rectángulo forman un clúster. Todos los equipos son físicos, excepto los F5 que están virtualizados. Existen tres dispositivos F5, dos en CPD principal y uno en respaldo.

Todos estos dispositivos están conectados mediante una capa de switches conectados con topología spine-leaf, con enlaces de muy alta velocidad y redundancia incorporada. En cada CPD existen dos switches spine que hacen las funciones de núcleo y están conectados con los leafs con enlaces de 40 Gbps. Los leafs son switches ToR (Top-of-Rack) que ofrecen conectividad a servidores 10Gb.

La conectividad de los servidores críticos se realiza a dos leafs que están formando un vPC, que a su vez montan un LACP o bonding contra los servidores. De esta manera se proporciona resiliencia ante la falla de un switch o enlace.



La organización ha implementado una infraestructura robusta con “best practices” de la industria: Existe diversidad de rutas físicas y alta disponibilidad en los enlaces, redundancia de hardware, y capacidad sobrada en la mayoría de tramos críticos. La arquitectura spine-leaf asegura baja latencia y alta escalabilidad horizontal, estando preparada para crecimiento futuro sin cuellos de botella evidentes. La única área de mejora identificada -el enlace de Fábrica de 1 Gbps- ya se encuentra en proceso de actualización (lo que demuestra una gestión proactiva de la capacidad). No se han detectado deficiencias mayores en esta subárea. Por el contrario, tras el incidente eléctrico del 28 de abril, FNMT-RCM (CERES) ha reforzado la importancia de la redundancia. En resumen, la base física de comunicaciones presenta un alto grado de resiliencia y fiabilidad, adecuado para construir sobre ella mejoras lógicas de conmutación y balanceo.

2.2.5 Capa lógica

La arquitectura lógica de la red de CERES combina una base moderna a nivel físico con ciertos enfoques tradicionales a nivel lógico. Como se indicó, la topología es spine-leaf en cada CPD, lo cual es positivo, sin embargo, la operación de dichos switches se realiza en modo clásico Layer 2 (conmutación) sin uso de tecnologías de virtualización de red como VXLAN/EVPN. En consecuencia, la red del CPD funciona esencialmente como un gran dominio L2 extendido con múltiples VLANs sobre la infraestructura spine-leaf.

El L3 de las VLANs donde cuelgan los servidores, se encuentran principalmente en los firewalls y alguno en los balanceadores, por lo que podemos decir que el enrutamiento se concentra principalmente en los firewalls y balanceadores.

En cuanto a la segmentación de la red, nos encontramos que la mayoría de las redes son /24 aunque existen algunas más pequeñas. El direccionamiento y VLAN ID que se utiliza en cada CPD es diferente. Como norma general las VLANs creadas en el CPD principal, tienen un “espejo” en el CPD de respaldo, pero con diferente direccionamiento y VLAN ID.

La segmentación, actualmente se basa en VLANs separando entornos (DMZ, backends, gestión, etc.) y reglas de firewall controlando el paso entre ellas. No se utiliza por ahora una solución de microsegmentación basada en software o identidades, aunque FNMT-RCM (CERES) ha manifestado interés en **SDN/Zero Trust** para segmentación este-oeste a nivel más granular (por ejemplo, a nivel de aplicación o carga de trabajo). Esto sugiere que la organización identifica la limitación de la segmentación actual y está investigando tecnologías para mejorarla.

Un aspecto notable es la existencia de **VLANs extendidas entre los dos CPDs**. Por necesidades de ciertos servicios o gestión, algunas redes locales están presentes simultáneamente en el CPD principal y el de respaldo (es decir, la misma subred se extiende por los enlaces inter-Centro de datos). Esto implica que el tráfico de esas VLANs puede fluir de un sitio a otro a nivel 2. Si bien esto facilita, por ejemplo, la migración de máquinas virtuales o la conmutación de ciertos servicios sin reenumerar IP, también conlleva complejidades. Se han **reportado asimetrías de tráfico** cuando, por ejemplo, una petición entra por un CPD pero la respuesta sale por el otro (debido a default gateways diferentes en cada ubicación). Para mitigar esto sobre la red actual, se han utilizado dos estrategias:

1. Realizar NAT en los firewalls para asegurar la vuelta del tráfico y conservar la simetría.
2. Montando un nuevo clúster F5 interno “extendido” que actúe como puerta de enlace intermedia normalizando el camino de retorno gracias a la característica “Auto Last Hop” de F5. Es decir, un balanceador configurado en ambos CPDs para una VLAN específica, de modo que reciba el tráfico y lo reenvíe siempre de vuelta por el mismo camino, evitando la asimetría.

La presencia de red extendida L2 genera, además de las asimetrías mencionadas, los riesgos clásicos de cualquier L2 amplio: posibilidad de tormentas de broadcast o bucles que afecten a ambos sitios, mayor dominio de fallo y desafíos para el spanning-tree. De hecho, en las reuniones se apuntó explícitamente este riesgo y la consideración de segmentar a L3 para eliminarlo. En la siguiente fase de la auditoría propondremos

posibles alternativas a este montaje para mitigar los posibles problemas comentados anteriormente.

Otro atributo de la arquitectura actual es que el núcleo de la red interna es L2: los switches core no realizan enrutamiento interno significativo, actuando más bien como agregadores con VLANs troncales. El routing principal se efectúa en los firewalls (Palo Alto para tráfico interno entre zonas, Fortinet para tráfico de entrada/salida) y balanceadores. Esto centraliza el control y la inspección de tráfico, pero a la vez puede limitar el rendimiento este-oeste (entre servidores del propio CPD) al pasar muchos flujos por los firewalls, y dificulta la microsegmentación dentro de un mismo segmento, pues todos los hosts en una misma VLAN se comunican libremente L2 a menos que se recurra a ACLs en switches, lo cual no se mencionó. La adopción progresiva de reglas L7 en el Palo Alto interno mitiga en parte la exposición, pero aún no cubre todo el tráfico.

En síntesis, la arquitectura de red actual está bien definida, pero presenta áreas de mejora significativas en cuanto a separación L2 Y L3 y segmentación. Existe una topología sólida y estándares implementados (spine-leaf, VLANs, firewall centralizado), pero persisten diseños heredados (VLANs extendidas, core L2) que incrementan la superficie de fallo y complejidad operativa. La situación actual cumple con los requerimientos funcionales, pero no aprovecha plenamente las tecnologías de virtualización de red ni las mejores prácticas de segmentación dinámica. La evolución hacia un modelo más distribuido (routing L3 en core o overlay EVPN) y un control de seguridad más cercano a los endpoints elevaría notablemente la madurez.

2.2.6 Hardware implementado

El objeto del presente punto es proporcionar el AS-IS del estado de la infraestructura de FNMT-RCM (CERES).

Marca	Hostname	Modelo	S/N	Version S.O.	EOS	EOL
F5 Balanceador	F5-HYPERV1	i5800	f5-cfxv-pyyf	BIG-IP 17.1.2.2	Mar 31, 2027	Jan 1, 2031
	F5-HYPERV2	i5800	f5-lnc-fwyg	BIG-IP 17.1.2.2	Mar 31, 2027	Jan 1, 2031
	F5-HYPERVBK	i5800	f5-huyt-cfp	BIG-IP 17.1.2.2	Mar 31, 2027	Jan 1, 2031
PaloAlto Firewall	fwinternobk	PA-3250	16301005123	11.1.6-h10	May 3, 2027	August 31, 2028
	fwinterno1	PA-3250	16301005125	11.1.6-h10	May 3, 2027	August 31, 2028
	fwinterno2	PA-3250	16301005126	11.1.6-h10	May 3, 2027	August 31, 2028
Fortinet Firewall	(UTP)JJ-DC-FW-AI-01	FortiGate-601E	FG6H1FTB22901337	v7.4.8	Novembre 11, 2027	not published
	(UTP)MN-DC-FW-AI-01	FortiGate-601E	FG6H1FTB22901572	v7.4.8	Novembre 11, 2027	not published
	(UTP)JJ-DC-FW-AI-02	FortiGate-601E	FMGVMSTM2300449	v7.4.7	Novembre 11, 2027	not published
FORCEPOINT Firewall	N325-2-C2	N325-2-C2	N0B8804004			May 10, 2028
	NGFW	N335-0-XX00-X-N	NC6A4500026			May 10, 2028
	NGFW	N335-0-XX00-X-N	NC6A4500039			May 10, 2028
CISCO Switch	SWITCH PKIPT	2950	FOC0819Z1J2	15.2(2)E6 ???	October 3, 2011	October 2, 2006
	03H57503	2960X	FOC1129Z6B0	15.2(2)E6	October 31, 2027	October 31, 2027
	JJ-DC-SW-BA-18 INT 2 0 1	2960X	FCW1940B0P4	15.2(2)E6	October 31, 2027	October 31, 2027
	JJ-DC-SW-BA-18 INT 1 0 1	2960X	FOC1255PVR	15.2(2)E6	October 31, 2027	October 31, 2027
	JJ-OE-SW-BA-01	2960X	FOC2017S38B	15.2(2)E6	October 31, 2027	October 31, 2027
	JJ-DC-SW-BA-18 INT 4 0 1	2960X	FCW2017B33N	15.2(2)E6	October 31, 2027	October 31, 2027
	JJ-DC-SW-BA-18 INT 3 0 1	2960X	FOC2017S3LX	15.2(2)E6	October 31, 2027	October 31, 2027
			WS-C2960X-48TS-L	15.2(2)E6	October 31, 2027	October 31, 2027
	03H57504	CATALYST2960G	FOC1132Z148	15.2(2)E6 ???	July 31, 2015	July 31, 2017
	JJPDSWBA04	CATALYST2960G	FOC1116Z5QQ	15.2(2)E6 ???	July 31, 2015	July 31, 2017
	JJPDSWBA03	CATALYST2960G	FOC1112Z89B	15.2(2)E6 ???	July 31, 2015	July 31, 2017
	JJPDSWBA01	WS-C2960X-48TS-LL	FWC1812A63A	15.2(2)E6	October 31, 2027	October 31, 2027
		CATALYST2960G		15.2(2)E6 ???	July 31, 2015	July 31, 2017
		CATALYST2960G		15.2(2)E6 ???	July 31, 2015	July 31, 2017
		CATALYST2960G		15.2(2)E6 ???	July 31, 2015	July 31, 2017
		CATALYST2960G		15.2(2)E6 ???	July 31, 2015	July 31, 2017
		WS-C3550-48-SM	CAT0643Z216D	15.2(2)E6	May 2, 2011	May 2, 2011
	SWITCH PKIPT2	WS-C3560G-48TS-S	FOC1250W208	15.2(2)E6	January 30, 2014	January 31, 2018
	JJ-DC-SW-BA-17	WS-C3560G-48TS-S	FOC1339Z3H7	15.2(2)E6	January 30, 2014	January 31, 2018
	JJPDSWBA02	WS-C3750G-24TS-S1U	FOC1328Y12A	15.2(2)E6	January 30, 2014	January 31, 2018
	JJ-DC-SW-BA-06	N9K-C93108TC-FX3P	SFDO27021J4U	version 9.3(10)	January 10, 2024	not published
	JJ-DC-SW-BA-07	N9K-C93108TC-FX3P	SFDO27021JLD	version 9.3(10)	January 10, 2024	not published
	JJ-DC-SW-BA-10	N9K-C93108TC-FX3P	SFDO27021JVO	version 9.3(10)	January 10, 2024	not published
	JJ-DC-SW-BA-08	N9K-C93108TC-FX3P	SFDO27021JW4	version 9.3(10)	January 10, 2024	not published
	JJ-DC-SW-BA-09	N9K-C93108TC-FX3P	SFDO27021JZU	version 9.3(10)	January 10, 2024	not published
	JJ-DC-SW-BA-12	N9K-C93108TC-FX3P	SFDO270227AE	version 9.3(10)	January 10, 2024	not published
	MN-DC-SW-BA-04	N9K-C93108TC-FX3P	SFDO270227AX	version 9.3(10)	January 10, 2024	not published
	MN-DC-SW-BA-07	N9K-C93108TC-FX3P	SFDO270227B8	version 9.3(10)	January 10, 2024	not published
	JJ-DC-SW-BA-05	N9K-C93108TC-FX3P	SFDO270227CC	version 9.3(10)	January 10, 2024	not published
	MN-DC-SW-BA-05	N9K-C93108TC-FX3P	SFDO270227D6	version 9.3(10)	January 10, 2024	not published
	MN-DC-SW-BA-06	N9K-C93108TC-FX3P	SFDO270227KUL	version 9.3(10)	January 10, 2024	not published
	JJ-DC-SW-BA-11	N9K-C93108TC-FX3P	SFDO270227VY	version 9.3(10)	January 10, 2024	not published
	JJ-DC-SW-BA-02	N9K-C9336C-FX2	FDO260316WH	version 9.3(10)	January 10, 2024	not published
	MN-DC-SW-BA-01	N9K-C9336C-FX2	FDO260327ZM	version 9.3(10)	January 10, 2024	not published
	JJ-DC-SW-BA-01	N9K-C9336C-FX2	FDO260328QJ	version 9.3(10)	January 10, 2024	not published
	MN-DC-SW-BA-02	N9K-C9336C-FX2	FDO260328S5	version 9.3(10)	January 10, 2024	not published
	MN-DC-SW-BA-03	N9K-C93240-FX2	FDO261522VT	version 9.3(10)	January 10, 2024	not published
	JJ-DC-SW-BA-04	N9K-C93240-FX2	FDO261406KS	version 9.3(10)	January 10, 2024	not published
	JJ-DC-SW-BA-03	N9K-C93240-FX2	FDO261522VX	version 9.3(10)	January 10, 2024	not published
	JJ-DC-SW-BA-14	N9K-C9348GC-FXP	FDO26301ZYW	version 9.3(10)	January 10, 2024	April 30, 2026
	JJ-DC-SW-BA-13	N9K-C9348GC-FXP	FDO26311ABV	version 9.3(10)	January 10, 2024	April 30, 2026
	JJ-DC-SW-BA-15	N9K-C9348GC-FXP	FDO26310TBL	version 9.3(10)	January 10, 2024	April 30, 2026
	MN-DC-SW-BA-08	N9K-C9348GC-FXP	FDO26310NPU	version 9.3(10)	January 10, 2024	April 30, 2026
	JJ-DC-SW-BA-16	2960X	FCW1813A103	15.2(2)E6	October 31, 2027	October 31, 2027
	JJ-DC-SW-BA-17	2960X	FOC1813W16C	15.2(2)E6	October 31, 2027	October 31, 2027

El análisis de esta tabla se realiza a partir de la información recibida.

Se ha destacado en rojo los dispositivos que ya están fuera de soporte y en caso de avería podría haber problemas para encontrar repuesto. Lo ideal sería realizar la sustitución por un nuevo hardware.

En el caso de la versión de software de los switches Nexus NX-OS 9.3(10), ya está fuera de soporte, pero se nos indicó que ya había un proyecto iniciado para migrar a la versión 10.4(4), la cual ya está dentro de soporte.

2.2.7 Direccionamiento IP

Direccionamiento público

En cuanto al direccionamiento público, como se ha comentado anteriormente, es propiedad de FNMT-RCM (CERES) y tiene AS propio. Actualmente existe bastante rango público libre.

Direccionamiento privado

A continuación, se adjunta una tabla con el direccionamiento privado que se utiliza dentro de la red FNMT-RCM (CERES)

DESCRIPCIÓN	Nombre de la red	Direccionamiento IP	VLAN Y DONDE ESTA EXTENDIDA
Red asignada FNMT en SARA	SVCSARA	10.121.8.0/24	
Red de interconexión F5 externos con routers SARA	RED_SARA	10.221.121.0/27	RESPALDO PRINCIPAL VLAN65
Red de acceso a servicios DMZ	DMZ1	192.168.130.0/24	RESPALDO PRINCIPAL VLAN10
Red de backend MZ	MZ	192.168.142.0/24	RESPALDO PRINCIPAL VLAN12
Red interna servicios PKI	PKI	192.168.148.0/24	RESPALDO PRINCIPAL VLAN102
Red de servicios internos (DNS,NTP,...)	GESTION	192.168.140.0/24	RESPALDO PRINCIPAL VLAN704
Red dominio operadores dedicada a servicios de autenticación	OPERADORES	192.168.134.0/24	RESPALDO PRINCIPAL VLAN21
Red de acceso antiguo servicio efactura	DMZEF	192.168.135.0/24	RESPALDO PRINCIPAL VLAN16
Red de acceso entornos aislados	DMZ2	192.168.131.0/24	NO RESPALDO NO PRINCIPAL VLAN8
Red de interconexión fwExterno y virtual servers servicios balanceados DMZ	DMZ1BAL	192.168.129.0/24	RESPALDO PRINCIPAL VLAN6
Red dedicada virtual servers para servicios balanceados MZ	MZBAL	192.168.141.0/24	RESPALDO PRINCIPAL VLAN7
Red en desuso	Entorno paralelo	192.168.136.0/24	RESPALDO PRINCIPAL VLAN0020
Red aislada para gestión firewalls externos (extendida)	GESTFWEXT	192.168.161.0/24	RESPALDO PRINCIPAL VLAN998
Red de administración de sistemas y firewalls internos (extendida)	GESTFWINT	192.168.160.0/24	RESPALDO PRINCIPAL VLAN250
Redes aisladas para interconexión con sistemas HSMS	HSMPKI	192.168.171.0/24	RESPALDO PRINCIPAL VLAN103
	HSMVAL	192.168.170.0/24	RESPALDO PRINCIPAL VLAN183
	HSMTX	192.168.173.0/24	RESPALDO PRINCIPAL VLAN190
Red de servicios de monitorización (Pandora, Zabbix)	MZ2	192.168.180.0/24	RESPALDO PRINCIPAL VLAN22
Red virtual servers para servicios balanceados de PKI	PKIBAL	192.168.147.0/24	RESPALDO PRINCIPAL VLAN101
Red Cluster Openshift	HUBCLUSTEROPENSIFT	192.168.194.0/24	PRINCIPAL VLAN25
Red de interconexión routers de proveedor y F5 externos	ISP	192.168.145.0/24	RESPALDO PRINCIPAL VLAN202
Red de interconexión firewalls externos y balanceadores externos F5	BRS	192.168.144.0/24	RESPALDO PRINCIPAL VLAN3
Red de interconexión F5 externos y entornos de FNMT	BRSEXT	172.16.240/24	RESPALDO PRINCIPAL VLAN4
Red de interconexión F5 internos con firewall interno	PREFWINT	192.168.146.0/24	RESPALDO PRINCIPAL VLAN9
VLAN para la configuración de isolated VLAN en DMZ2	DMZ2ISOL		RESPALDO PRINCIPAL VLAN11
Red dedicada openshift cluster network	OPENSIFT CN	172.31.0.0/18	RESPALDO PRINCIPAL VLAN23
Red dedicada contenedores openshift	OPENSIFT	192.168.193.0/24	RESPALDO PRINCIPAL VLAN23
Red de servicios de sincronización de tiempos de ROA	ROA	192.168.190.64/26	RESPALDO PRINCIPAL VLAN24
Red de gestión de sistemas del centro principal a través de las ILOM	ILOMS	192.168.10.0/24	RESPALDO PRINCIPAL VLAN61
Red para el intercambio de claves en las unidades de cinta LTO	LTO	192.168.149.0/24	RESPALDO PRINCIPAL VLAN62
Red de interconexión entre CPDs principal y respaldo con firewalls enfrentados (extendida)	CONCENTROS	192.168.150.0/24	RESPALDO PRINCIPAL VLAN300
Redes de heartbeat sistemas Oracle	HB_BBDD-7-8	???????	RESPALDO PRINCIPAL VLAN333
	HB_Oracle_BBDD-5-6	???????	RESPALDO PRINCIPAL VLAN334
	HB1_BBDD-1-2	???????	RESPALDO PRINCIPAL VLAN335
	HB2_BBDD-1-2	???????	RESPALDO PRINCIPAL VLAN336

DESCRIPCIÓN	Nombre de la red	Direccionamiento IP	VLAN Y DONDE ESTA EXTENDIDA
Redes heartbeat clusters Veritas	HB_VERITAS_DATOS3y4	???????	RESPALDO PRINCIPAL VLAN340
	HBVeritas_Aplicaciones	???????	RESPALDO PRINCIPAL VLAN341
VLAN para configuración de cifrado antiguo DWDM centro de respaldo	CYPHER_CONCENTROS	???????	RESPALDO PRINCIPAL VLAN350
Redes interconexión sistemas F5 para HA	HA_Externa_F5	1.1.3.0/24	RESPALDO PRINCIPAL VLAN544
	VLAN0555 (HA_INTERNA_F5)	1.1.1.0/24	RESPALDO PRINCIPAL VLAN555
	VLAN0556 (HA_INTERNA_F5)	1.1.2.0/24	RESPALDO PRINCIPAL VLAN556
Red cluster Oracle PKI	HEARTBIT_DATOSPKI	???????	RESPALDO PRINCIPAL VLAN601
Vlan a eliminar	Migracion_FW	???????	RESPALDO PRINCIPAL VLAN777
	GestionConsolasRespaldo	???????	RESPALDO PRINCIPAL VLAN778
VLAN para monitorización de tráfico de red	QRADAR_MIRROR	???????	RESPALDO PRINCIPAL VLAN823
	CAPTURAPAMBK	???????	RESPALDO PRINCIPAL VLAN833
	RSCNI	???????	RESPALDO PRINCIPAL VLAN879
	NUEVASONDACNI	???????	RESPALDO PRINCIPAL VLAN880
Red de antiguo entorno de digitalización	ILO-PROV-EFEC	???????	NI RESPALDO NI PRINCIPAL VLAN60
Red para el traspaso de claves a las unidades LTO del sistema OKM (ya dado de baja)	Cifrado_OKM	???????	RESPALDO PRINCIPAL VLAN921
Red sistema de almacenamiento en centro principal	CES	192.168.189.0/24	RESPALDO PRINCIPAL VLAN126
Red de interconexión sistemas de almacenamiento	DAEMON	192.168.188.0/24	RESPALDO PRINCIPAL VLAN127
Red backend VAs windows	MZ3	192.168.165.0/28	RESPALDO PRINCIPAL VLAN128
Red dedicada para la interconexión de eventos CORTEX	CORTEX	192.168.165.16/28	RESPALDO PRINCIPAL VLAN401
Red de servicio nuevo entorno Qradar (extendida)	SERVICE-QRADAR	192.168.165.32/28	VLAN403
Red de acceso nuevo servicio Qradar (extendida)	ACCESS-QRADAR	192.168.165.48/28	VLAN404
VLAN para la asignación de puertos sin uso	Dummy		RESPALDO PRINCIPAL VLAN999
Red del entorno productivo de personalización de tarjetas	PKIPT	192.168.2.0/24	PRINCIPAL VLAN18
	RESPALDO		
Red de acceso a servicios DMZ en respaldo	DMZBK	192.168.30.0/24	RESPALDO PRINCIPAL VLAN204
Red de backend entorno Clave	MZ4	192.168.66.0/28	PRINCIPAL VLAN31
Red de bddd entorno Clave	BBDD	192.168.67.0/28	PRINCIPAL VLAN32
Red de backend MZ en respaldo	MZBK	192.168.42.0/24	RESPALDO PRINCIPAL VLAN203
Red interna servicios PKI en respaldo	PKIBK	192.168.48.0/24	RESPALDO PRINCIPAL VLAN211
Red de servicios internos (DNS,NTP,...) en respaldo	GESBK	192.168.40.0/24	RESPALDO PRINCIPAL VLAN205
Red dominio operadores dedicada a servicios de autenticación en respaldo	OPERBK	192.168.34.0/24	RESPALDO PRINCIPAL VLAN206
Redes aisladas para interconexión con sistemas HSMs	HSMVALBK	192.168.70.0/24	RESPALDO PRINCIPAL VLAN209
	HSMTXKBK	192.168.73.0/24	RESPALDO PRINCIPAL VLAN212

DESCRIPCIÓN	Nombre de la red	Direccionamiento IP	VLAN Y DONDE ESTA EXTENDIDA
Red de interconexión fwExterno y virtual servers servicios balanceados DMZ respaldo	DMZBKBalanceada (RED_29)	192.168.29.0/24	VLAN222
Red dedicada virtual servers para servicios balanceados MZ	MZBKBalanceada	192.168.41.0/24	SIN VLAN ASIGNADA
Red dedicada para servicios VMWare de vMotion	VMOTION	192.168.191.0/24	RESPALDO PRINCIPAL VLAN400
Red virtual servers para servicios balanceados de PKI respaldo	PKIBKBAL (RED_47)	192.168.47.0/24	RED_47 EN RESP Y PRINC VLAN221
Red hub cluster openshift respaldo	HUBCLUSTEROPENSHTFTBK	192.168.94.0/24	RESPALDO VLAN125
Red de servicios de sincronización de tiempos de ROA centro de respaldo	INTERNA_ROABK	192.168.190.128/26	RESPALDO PRINCIPAL VLAN124
Red de gestión de sistemas del centro de respaldo a través de las ILOM	ILOMBK	192.168.11.0/24	RESPALDO PRINCIPAL VLAN161
Red para el intercambio de claves en las unidades de cinta LTO centro de respaldo	LTOBK	192.168.49.0/24	RESPALDO PRINCIPAL VLAN162
Red sistemas de gestión de accesos privilegiados	PAM	192.168.185.0/24	RESPALDO PRINCIPAL VLAN185
Red de servicios de monitorización respaldo	MZ2BK	192.168.80.0/24	RESPALDO PRINCIPAL VLAN207
Redes aisladas para interconexión con sistemas HSM respaldo	HSMPPKIBK	192.168.71.0/24	RESPALDO PRINCIPAL VLAN213
Red sistemas de gestión de accesos privilegiados centro de respaldo	PAMBK	192.168.85.0/24	RESPALDO PRINCIPAL VLAN285
Red dedicada contenedores openshift respaldo	OPENSHTFTBK	OPENSHTFTSVC?? 192.168.93.0/24 ??	RESPALDO PRINCIPAL VLAN123
Red sistema de almacenamiento en respaldo	CESBK	192.168.89.0	RESPALDO PRINCIPAL VLAN129
Red backend VAs windows	MZ3BK	192.168.65.0/28	RESPALDO VLAN130
Red de backend entorno Clave respaldo	MZ4KBK	192.168.166.0/28	RESPALDO VLAN131
Red de bddd entorno Clave respaldo	BBDBBK	192.168.167.0/28	RESPALDO VLAN132
Red dedicada envío de eventos Cortex en respaldo	CORTEXBK	192.168.65.16/28	RESPALDO VLAN402
Red en desuso	INTERCONEXPKIPT (PKIPT)	192.168.3.0/24	PKIPT VLAN502
Red dedicada interconexión sistemas HSM entorno de producción personalización de tarjetas	HSMPPKIPT (PKIPT)-ANTIGUA NCIPHER	10.0.0.0/24	PKIPT VLAN2
Red en desuso	FABRICACIONTARJETAS (PKIPT)	192.168.4.0/24	PKIPT VLAN3
Red dedicada interconexión sistemas HSM entorno de producción personalización de tarjetas	HSMPPKITAR	10.0.0.0/24	???????
	Preproducción	Prepro	Pendiente
Red de desarrollo	DESA (PREPRO)	192.168.1.0/24	PREPRO VLAN30
Red openshift preproducción	OPENSHTFT (PREPRO)	192.168.192.0/24	PREPRO VLAN32
Red para servicio de réplica BBDD integración	REPLICABDDINTEGRA	192.168.88.0/28	PREPRO VLAN71
Red de gestión ILO sistemas preproducción	IDRACINTEGRA	192.168.12.0/24	PREPRO VLAN72
Red de gestión sistemas Integración	GESTINTEGRA	192.168.63.0/24	PREPRO VLAN73
	SEG46BK (RED_46)	192.168.46.0/24	VLAN224 0 226?????
Red aislada entorno de preproducción	RED AISLADA 61 PREPRO	192.168.61.0/24	VLAN123 PREPRODUCCION
Red almacenamiento entorno de producción personalización de tarjetas (ya en desuso)	SCSIA (PKIPT)	192.168.122.0/24	PKIPT VLAN997
	SCSIB (PKIPT)	192.168.123.0/24	PKIPT VLAN996

2.2.8 Publicación y acceso a servicios (Akamai, Red SARA)

En este dominio se engloban los mecanismos mediante los cuales los usuarios externos (ciudadanos, organismos públicos) acceden a los servicios de CERES, ya sea vía Internet o vía la Red SARA, así como el uso de plataformas intermedias como Akamai. La situación actual es la siguiente:

- **Uso de Akamai (CDN/WAF):** FNMT-RCM (CERES) utiliza la red Akamai para la publicación de ciertos servicios, principalmente los portales web públicos y contenido estático de CERES. Akamai actúa como CDN (sirviendo contenidos cacheados) y como primera capa de WAF para esas aplicaciones web, protegiéndolas de ataques comunes. El usuario externo típicamente accede a la URL de CERES, que resuelve a Akamai, y éste luego se comunica con la infraestructura FNMT-RCM (CERES). Sin embargo, es importante señalar que la mayoría de los servicios de aplicación no están detrás de Akamai, sino que “entran directos al CPD”. Es decir, solo ciertos pasan por la CDN, mientras que otros servicios son consumidos mediante acceso directo a las IPs de FNMT-RCM (CERES) (por Internet o vía SARA).

Frontales en AKAMAI
CERES
www.cert.fnmt.es
www.ceres.fnmt.es

ESCUELA DE GRABADO
www.escueladegradadofnmt.org
www.escueladegradadofnmt.org

FNMT
www.fnmt.es
www.fnmt.com
www.fnmt.eu
www.fnmt.net
www.fnmt.org

MUSEO
www.museocasadelamoneda.com
www.museocasadelamoneda.es
www.museocasadelamoneda.org

SEDE
www.sede.fnmt.gob.es
www.sede.fnmt.gob.es

SIAEN
www.siaen.org
www.siaen.es

- Tráfico directo al CPD sin pasar por WAF ni por Akamai: Muchos servicios no utilizan Akamai. Esto puede incluir APIs de backend, servicios para aplicaciones móviles, o quizá servicios para otros organismos que no sean web. Estos servicios entonces dependen de la seguridad provista por los firewalls perimetrales y la propia robustez de las aplicaciones, ya que no están detrás del WAF en la nube.

Dominios que se accede directamente a CERES
aplicaciones.fnmt.es
casamoneda.es
demo.ceres.fnmt.es
demo.cert.fnmt.es
fnmt-rcm.eu
monedavirtual.es
monedavirtual.eu
realcasadelamoneda.eu
spanishroyalmint.org
virtualcoin.es
virtualcoin.eu

- Publicación a través de Red SARA: La Red SARA es la red privada de la Administración que conecta organismos públicos. FNMT-RCM (CERES) ha consolidado sus comunicaciones con AA.PP. usando SARA, sustituyendo antiguas líneas dedicadas. En la práctica, muchos servicios de CERES son consumidos tanto por Internet como por organismos vía SARA. Para ello, se tiene un esquema en el que los mismos virtual servers (VIP) en F5 escuchan en ambas redes: pública e SARA. Cuando la petición viene de SARA, se aplica un NAT de presentación a una IP interna del servicio en los F5 externos. Esto significa que, por ejemplo, un servicio de validación tiene una IP virtual pública (accesible vía Internet) y otra IP en el rango SARA, ambas terminan en el mismo pool de servidores internos; el tráfico pasa por el firewall perimetral para su filtrado, pero la traducción NAT se realiza en los F5, sin aplicar NAT adicional en los firewalls. Los routers SARA están ubicados en el CPD de Fábrica (principal) y operan en alta disponibilidad activo-pasivo. Como se comentó anteriormente en el CPD de respaldo hay otros dos en modo pasivo.
- Servicios SaaS externos: Se menciona el caso de video identificación, donde una parte del proceso se realiza en un proveedor SaaS externo, descargando luego resultados a CERES como parte de un flujo completo de video identificación. Esto indica que existen integraciones con terceros para funciones específicas (no influye tanto en networking local, salvo asegurar canales seguros para esas descargas).
- Anti-DDoS y entradas múltiples: Actualmente, aunque existe multihoming con varios operadores, en la práctica una parte muy relevante del tráfico de Internet entra habitualmente por un único upstream (CPE) antes de F5. No se explotan mecanismos de GSLB en DNS externo, por lo que no hay un reparto de usuarios a nivel de resolución de nombres. La protección Anti-DDoS de Akamai (Prolexic) está en proceso de activación para cubrir ataques volumétricos a los servicios publicados. En Telefónica existe contratado otro servicio de DDoS, mientras que COLT no tiene ninguna protección. Mientras tanto, un ataque DDoS grande podría saturar el ancho de banda.

En cuanto a la publicación de servicios, a modo resumen podemos decir que, se emplea una solución avanzada de CDN/WAF (Akamai) para los portales web, lo que es una buena práctica.

También se ha centralizado la entrada de organismos vía SARA, asegurando cifrado y gestión centralizada. Por otro lado, no todos los servicios están igualmente protegidos: el hecho de que muchos entren directos al CPD implica que no se benefician del WAF de Akamai ni de la distribución global. Esto genera una disparidad en el nivel de seguridad/exposición según el servicio. Asimismo, siguen existiendo dependencias de la Red SARA respecto a la extensión L2 y a la red de Fábrica, que pueden afectar a la conectividad en caso de incidencias en esa capa. No obstante, en el CPD de respaldo existen dos routers de SARA que permiten mantener el acceso a los organismos públicos incluso en escenarios de caída del CPD principal.

2.2.9 Balanceo de carga (F5 BIG IP)

FNMT-RCM (CERES) emplea una plataforma de balanceo de carga F5 BIG-IP para distribuir el tráfico de servicios tanto a nivel perimetral (externo) como a nivel interno. Físicamente existen dos F5 en CPD principal y uno en el de respaldo, que están virtualizados ofreciendo las capas que se explican a continuación:

- F5 perimetrales (externos): Está compuesto por un clúster de tres balanceadores virtualizados, extendido entre los dos CPDs (activo-pasivo/pasivo). Dos en el CPD principal y uno en el de respaldo. Las funciones de este clúster son las de publicar los servicios, tanto a Internet como a la red SARA. Normalmente el mismo servicio se publica por los dos accesos con IP diferentes.
 - De cara a Internet, el F5 realiza NAT del direccionamiento público de FNMT-RCM (CERES) contra una IP privada del balanceador interno.
 - De cara a la red SARA, el balanceador realiza un NAT de un direccionamiento asignado de la red SARA para presentar los servicios hacia dicha red. Este NAT va dirigido contra una IP privada del balanceador interno.

Como punto a remarcar en esta capa, cada VIP tiene configurada una granja del CPD principal y otra en la de respaldo. Se están afinando las configuraciones de los monitores para tener más granularidad a la hora de pasar servicios de un CPD al otro.

- F5 internos: Está compuesto por un clúster de dos balanceadores virtuales en HA en el CPD principal y otro balanceador virtual en modo standalone en CPD de respaldo. La función de estos balanceadores es publicar las VIPs internas y redirigir el tráfico a la granja de webservers o bien de application servers. Una funcionalidad importante a nivel de seguridad es que en esta capa se aplica política de WAF a las VIPs y un servicio Anti-DDos básico del propio balanceador. Se utilizan particiones para separar algunos servicios como DMZ, PKI y OPENSIFT.
- F5 interno extendido: Es un nuevo clúster que se está probando para la aplicación SIEM. Todavía no está productivo. Está montado sobre una VLAN extendida y la principal funcionalidad de este balanceador, es la de utilizarlo como gateway con la característica “auto Last Hop” activada para saber hacia qué CPD devolver el tráfico y así evitar asimetrías.

Cabe destacar que todo el balanceo que se realiza en los balanceadores es de L4, dejando “la inteligencia” de la toma de decisiones de balanceo a los apaches que están haciendo funciones de L7, como por ejemplo, redirigir el tráfico en función de la URL.

El nivel de madurez actual en balanceo de carga se evalúa como Nivel 3 (Estandarizado). La FNMT-RCM (CERES) cuenta con tecnología avanzada (F5 es líder de mercado) y ha implementado clústeres en su CPD principal, asegurando alta disponibilidad local. Hay procedimientos claros para publicar servicios mediante VIPs en F5, tanto para usuarios de Internet como para tráfico interno y de la Red SARA. Sin embargo, existen limitaciones importantes. En particular, la ausencia de un esquema de balanceo global que reparta la carga entre CPD principal y secundario automáticamente. Todo el tráfico depende del clúster externo, creando un punto crítico. Un fallo de configuración en este clúster podría causar un cero en la red. Además, en el CPD secundario los elementos no están redundados. Esto reduce la resiliencia en escenarios de contingencia, ya que una falla en esos elementos en pleno uso degradaría el servicio.

En resumen, el balanceo de carga está bien instaurado (todos los servicios utilizan VIPs tanto para usuarios públicos como internos), aunque se están delegando funciones de propias del F5 en los servidores apache. Precisamente el potencial de F5 está principalmente en la posibilidad de configurar iRules (scripts para gestionar y optimizar el tráfico). De cara a pensar en poner los dos CPDs a trabajar como activo/activo, sería recomendable que ciertas funciones de L7 las hiciese el F5. Esto podría comportar la reconfiguración de alguna de las aplicaciones. La arquitectura actual podría mejorar en cuanto a distribución geográfica y redundancia en CPD secundario para alcanzar un nivel de madurez superior.

2.2.10 Seguridad (Firewalls, segmentación interna, WAF, DDoS)

Firewalls

La seguridad perimetral y la segmentación interna en FNMT-RCM (CERES) se implementan mediante un esquema de doble capa de firewalls de fabricantes distintos:

- En el perímetro externo (frontera con Internet y red SARA) se sitúan firewalls Fortinet. Son tres firewalls físicos, desplegados dos en el CPD principal formando un clúster de HA y otro en el CPD de respaldo en modo stand alone. Esta capa de firewalls es la encargada de filtrar el tráfico que entra o sale hacia Internet. Según lo analizado, las reglas en estos firewalls son L4 tradicionales, basadas en dirección IP origen/destino y puerto, aunque el equipamiento dispone e implementa módulos de seguridad avanzados (IPS, antivirus, etc.) que complementan la inspección. El volumen aproximado de reglas en esta capa es de aproximadamente 200 reglas, con una regla de cierre de política al final. Todas ellas están logadas y se están enviando a un syslog. En la revisión realizada, se observa que se intenta seguir el criterio de agrupar las reglas en función del servicio. Debido al apagón sucedido hace unos meses, en la actualidad se está llevando a cabo un proyecto para cerrar VPN contra estos firewalls en ambos centros, para asegurar un acceso diferente del actual.
- En la capa interna (entre la DMZ y las redes internas de backend) se utilizan firewalls de nueva generación Palo Alto Networks. Son tres firewalls físicos, desplegados dos en el CPD principal formando un clúster de HA y otro en el CPD de respaldo en modo stand alone. La función de estos firewalls es filtrar el tráfico entre las diferentes VLANs a las que están conectados. Los firewalls están actuando como gateway para todas las VLANs. Cada VLAN corresponde a una zona diferente en el firewall. Actualmente, la política de estos Palo Alto está en transición de L4 a L7: se han comenzado a usar reglas basadas en App-ID (identificación de aplicaciones) para filtrar por tipo de aplicación y contenido. El volumen de reglas es aproximadamente de unas 900 reglas, todas ellas logadas. En la estructura de la política se observa se ha intentado seguir un criterio en la configuración de las reglas, agrupadas por servicio y existe una denegación de cierre al final. Como último punto destacable, los Palo Alto tienen activada la licencia de Threat Prevention que se renueva anualmente.

Segmentación interna

En cuanto a la segmentación interna: Además de la separación que brindan las VLANs y los firewalls, no existe por ahora microsegmentación más fina. La estrategia es avanzar en App-ID en Palo Alto (filtrar por la aplicación efectiva y no solo por puerto) para evitar tráfico no deseado disfrazado en puertos permitidos. Se evalúa a futuro alguna herramienta de microsegmentación de red para controlar accesos dentro de segmentos.

WAF

El servicio de WAF (Web Application Firewall) es un tipo de firewall especializado que protege las aplicaciones web filtrando y monitoreando el tráfico HTTP entre Internet y la aplicación. Actualmente existen dos puntos de la red donde está aplicada la seguridad de WAF. El primero es en AKAMAI, protegiendo las webs publicadas desde allí. No se ha tenido acceso a ninguna revisión.

El segundo punto es en los F5 internos. Existen políticas de seguridad aplicadas, pero no hay ningún patrón específico definido. Principalmente se deniega lo que es obvio que no debe de llegar. Los logs se envían al SIEM para su posterior análisis.

DDoS

El servicio de mitigación de ataques DDoS (Distributed Denial of Service) se encarga de proteger infraestructuras de red, aplicaciones, servicios y sitios web frente a intentos de saturación mediante tráfico distribuido malicioso. Su objetivo es preservar la disponibilidad y continuidad operativa de los recursos en línea, minimizando el impacto en el rendimiento y asegurando el acceso legítimo de los usuarios mediante mecanismos de filtrado, balanceo de carga y detección en tiempo real.

Actualmente existe un servicio de DDoS contratado en el CPD principal con Telefónica, aunque está en curso la implementación de un proyecto con Prolexic de AKAMAI para proteger toda la red.

Estado de madurez

Considerando todo lo anterior, el nivel de madurez actual se califica en Nivel 3 (Estandarizado). La organización tiene controles de seguridad bien establecidos, con tecnología NGFW puntera y políticas definidas (deny all, segregación por zonas, doble control de cambios). Sin embargo, la implementación completa de capacidades avanzadas (App-ID al 100%) está en progreso pero no terminada. Asimismo, existen puntos de falla únicos (firewalls en DR) que bajan la nota de resiliencia. En un modelo maduro (4-5) se esperaría HA en todos los sitios, uso pleno de políticas L7, y quizás automatización en despliegue de políticas, aspectos aún por completar.

2.2.11 DNS (Servicio de nombres, interno y externo)

La infraestructura DNS de CERES está dividida en dos ámbitos claramente diferenciados:

- **DNS Externo:** Los dominios públicos de la FNMT-RCM (CERES) se encuentran delegados en la plataforma de Akamai. En la práctica, esto significa que FNMT-RCM (CERES) utiliza el servicio de DNS gestionado de Akamai, administrándolo a través de su panel de control. Esta solución aporta redundancia global (Akamai distribuye sus servidores DNS por continentes) y facilita la integración

con servicios como el balanceo geográfico. Es adecuado considerando que muchas peticiones vendrán de usuarios de Internet variados. Actualmente, por ejemplo, las entradas DNS de los portales apuntan a Akamai (que luego redirige al origen), y otras entradas, como las de servicios directos, apuntan a IPs públicas de FNMT-RCM (CERES). El listado de dominios ya se ha proporcionado en apartados anteriores.

- DNS Interno: Para la resolución de nombres dentro del CPD, FNMT-RCM (CERES) mantiene servidores virtuales BIND propios. Se mantienen dos instancias por CPD que funcionan con una VIP por encima para proporcionar alta disponibilidad y resiliencia. Estos servidores proporcionan las resoluciones internas hacia las IP privadas para resoluciones internas. Adicionalmente existen otros BIND en DMZ que actúan como resolvers, destinados a resolver nombres externos.

En general, el servicio DNS se encuentra bien diseñado y operado. A nivel de redundancia, el DNS externo al residir en Akamai ofrece una redundancia robusta global. El DNS interno, al estar configurado debajo de VIPs y en ambos CDPs ofrece es altamente redundante.

No se han reportado incidencias ni carencias en este ámbito durante las reuniones. Por ello, se evalúa su madurez actual en Nivel 3 alto (Estandarizado) dentro del dominio DDI: servicio centralizado y replicado, separación interno y externo y alta disponibilidad. Para alcanzar Nivel 4 se requieren automatizaciones y validaciones sistemáticas (p. ej., DNSSEC, pruebas periódicas de restore y ciclo de cambios integrado con CMDB e IPAM) con evidencias registradas.

2.3. Políticas operativas de gestión

En este apartado se pretende recoger los más importante comentado en las reuniones, respecto a los procedimientos de gestión del día a día.

2.3.1 Gestión de la Red

En cuanto a la operativa de administración de los switches se realiza mediante CLI. Aunque se dispone de la herramienta Nexus Dashboard Fabric Controller, que facilitaría la administración y limitaría el posible error humano. El motivo es que debido a la carga del día a día, no se ha conseguido tener tiempo suficiente para formar al personal.

En lo que respecta a los F5, se administran los clústeres por separado vía GUI.

2.3.2 Gestión de la Seguridad

Reglas de FW

Los firewalls Palo Alto, se administran directamente por GUI. Para los firewalls FortiGate, existe la consola centralizada de FortiManager.

Esta sección se refiere a cómo se administran y controlan los cambios en las reglas de firewall y otras políticas de seguridad operativa. FNMT-RCM (CERES) ha establecido un proceso formal y segregado para la gestión de las reglas de firewall:

- Existe una política de doble control: Un responsable introduce la regla solicitada y otro diferente la revisa y aprueba antes de aplicarla, cumpliendo así con la separación de funciones y creando un rastro de auditoría. Este procedimiento está alineado con estándares de seguridad y asegura que no se aplican cambios de reglas sin revisión independiente.
- La carga principal de trabajo reportada es la de altas de nuevos servicios y apertura de puertos relacionados. Cada vez que se pone en producción un nuevo servicio o se requiere que cierto sistema se comunice por un puerto que antes no tenía permitido, se tramita una solicitud de regla. Dado el número de reglas (~900 en el interno) y la complejidad creciente, este proceso consume mucho tiempo de los equipos de infraestructura, redes y seguridad.
- Las reglas se agrupan por servicio. Luego el personal técnico implementa la regla en los firewalls correspondientes.
- En cuanto a gobernanza, cada cambio queda auditado en los logs de administración de los equipos y en los tickets o actas de cambio. Al ser un entorno regulado, es de suponer que mantienen un registro para auditorías.
- Recertificación y limpieza de reglas: Actualmente se está implantando un proceso de revisión periódica de las reglas, supervisado y contrastado a través de las auditorías internas de ASIN. No obstante, al encontrarse todavía en fase de consolidación, persiste el riesgo de que, si no se mantiene un saneamiento continuo y sistemático, puedan permanecer reglas obsoletas en la configuración.
- Tiempo de provisión elevado: Debido a la carga operativa, a la segregación de funciones y a la falta de recursos dedicados, el personal que realiza estas tareas debe compatibilizarlas con labores de administración de sistemas e implantación de proyectos. En consecuencia, aprobar e implementar una nueva regla puede llevar un tiempo no trivial, lo que afecta a proyectos que requieren apertura ágil de puertos.

En general, la gestión de reglas está formalizada y controlada, lo que es muy positivo en términos de cumplimiento y orden. No se evidenciaron violaciones a procesos ni gestión caótica, al contrario, hay una disciplina marcada por auditoría. Por tanto, se la puede calificar en Nivel 3 (Estandarizado). Para alcanzar niveles superiores, se debería incorporar más automatización y herramientas especializadas que ayuden a

optimizar y limpiar reglas, y un gobierno cíclico de las mismas (recertificación periódica con los dueños de aplicaciones, etc.). Dado que esas prácticas avanzadas aún no están plenamente implantadas, el nivel 3 es el adecuado.

Gestión de accesos privilegiados (PAM) y trazabilidad

La gestión de accesos administrativos en FNMT-RCM (CERES) está soportada por una solución de Privileged Access Management (PAM) denominada “SafeGuard”. Según lo discutido, las prácticas actuales son:

- Todo el personal que necesita acceder a sistemas con privilegios (administradores de sistemas, de red, DBAs, etc.) lo hace a través de esta herramienta PAM, usando sus credenciales nominales (personales). Es decir, cada usuario administrador ingresa al PAM con su identidad propia y desde allí obtiene acceso a los distintos sistemas target. Esto es muy importante porque elimina el uso directo de cuentas genéricas compartidas sin control.
- Acceso en entornos Windows: En servidores o sistemas Windows, cada administrador accede inicialmente con su cuenta nominal con privilegios mínimos y, cuando necesita realizar una acción administrativa, debe solicitar a través del PAM una contraseña de administrador sobre el sistema. Esa credencial privilegiada se entrega de forma controlada y se rota automáticamente tras su uso, manteniendo así trazabilidad y reduciendo la exposición de cuentas de alto privilegio.
- Acceso en entornos Linux/Unix (RHEL): Aquí la práctica es que, mediante PAM, el usuario nominal se conecta pero luego su sesión se canaliza hacia una cuenta genérica del servidor (por ejemplo root u otra cuenta de servicio), con un mapeo por grupos. Es decir, varios usuarios pueden terminar usando la misma cuenta en el servidor, pero el PAM se encarga de registrar quién es el que la está usando. Por tanto, hay trazabilidad entre nominal y genérico incluso cuando técnicamente en el sistema la acción la realiza una cuenta genérica.
- Grabación de sesiones: Todas las sesiones gestionadas a través del PAM quedan grabadas en vídeo o log detallado. Esto significa que cada comando o acción de un administrador en los sistemas críticos puede ser reproducido o auditado posteriormente. Es una capacidad valiosa para investigar incidentes o cumplir regulaciones de trazabilidad.
- Estado del PAM: No se reportaron deficiencias, se da a entender que la herramienta existe, funciona y cubre lo necesario. Los principios se cumplen: cuentas nominales, session recording, correlación de identidades.

Con estos datos, la capacidad de PAM es elevada y alineada a buenas prácticas (cuentas nominales, session recording, trazabilidad). A efectos de consolidación de madurez de la torre, esta capacidad suma en el dominio Observabilidad, operación y continuidad, que hoy se mantiene en Nivel 3 por la automatización dispar y evidencias no homogéneas en otros sub-bloques.

Pocos organismos cuentan con un PAM completamente desplegado y obligatorio para todos los accesos. FNMT-RCM (CERES) demuestra un nivel de control robusto, acorde a buenas prácticas de seguridad (y a controles ENS de nivel alto sobre trazabilidad). Para un nivel 5 absoluto, se podría aspirar a automatizar más la gestión de credenciales (rotación frecuente de contraseñas, eliminar incluso las cuentas genéricas en Linux usando servicios de AD, etc.), pero el avance actual ya es notable.

Gestión de cambios, parches y continuidad operativa

La gestión de cambios de infraestructura y la gestión de parches de seguridad en CERES se realiza de acuerdo con un ciclo planificado y con la monitorización de vulnerabilidades proveniente tanto de fabricantes como del SOC de la FNMT-RCM (CERES):

- Existe un proceso de gestión de vulnerabilidades: Se reciben alertas de los fabricantes (por ejemplo, boletines de Cisco, Microsoft, etc.) y del SOC interno o proveedor de seguridad, así como de una

sonda de vulnerabilidades denominada “NESSUS” que escanea el entorno. Esto permite enterarse de fallos de seguridad que afecten a componentes del entorno.

- Ciclo de parcheo periódico: Aproximadamente cada 6 meses se realiza la aplicación de parches de sistema operativo de forma generalizada. Este sería el ciclo regular para servidores, sistemas de almacenamiento, etc. Adicionalmente, cuando surge una vulnerabilidad crítica (CVE crítica) que afecta a la plataforma, se aplican parches urgentes fuera de ciclo sin esperar a la ventana semestral. Esto demuestra capacidad de reacción ante amenazas graves (por ejemplo, un fallo tipo Log4Shell o similar fue probablemente atendido inmediatamente en su momento).
- Disponibilidad 24x7 y ventanas limitadas: CERES es un servicio 24x7, por lo que se evita interrumpirlo salvo que sea inevitable. Se menciona que solo se programa parada si es imprescindible, buscando aplicar parches en caliente o apoyarse en mecanismos de alta disponibilidad. Cuando es preciso reiniciar servicios, se planea una ventana específica fuera de horario crítico. La disponibilidad del personal interno no es estrictamente 24x7 por reglamentación, sino que se articula mediante un contrato de guardias 24x7 con capacidad de actuación limitada y, en algunos casos, decisiones personales para atender incidencias fuera de horario. En conjunto, se observa una fuerte conciencia de la continuidad operativa, reforzada tras el incidente del apagón del CPD principal.
- Gestión de cambios general: No se detalló, pero es de suponer que existe un comité de cambios o al menos un flujo formal: para cada parche o cambio significativo (configuraciones de red, actualización de firmware, etc.) se levanta un pedido de cambio, se prueba en entornos no productivos, se aprueba y agenda en producción. Esto encaja con las mejores prácticas ITIL, necesarias en un entorno con alta criticidad. La reunión no explicitó este proceso, pero al mencionar “solo se programa parada si inevitable” se deduce que hay planeación.
- Lecciones aprendidas de continuidad: Tras el incidente del apagón (28 de abril, en el que cayó el CPD principal afectando todo), la FNMT-RCM (CERES) ha tomado acciones (por ejemplo, la VPN de gestión en respaldo) para mejorar. Esto indica que integran la gestión de continuidad en su modelo: analizan incidentes y toman medidas para no repetirlos. También se habla de aspiración a activo-activo para reducir tiempos de recuperación.

La madurez actual en gestión de cambios y parches se sitúa en Nivel 3 alto (Estandarizado): proceso planificado y disciplinado (ciclo semestral y urgentes), aún sin automatización extendida, SLO/KPI operativos y validaciones end-to-end que cierran el ciclo de mejora continua, por ello, el dominio Observabilidad, operación y continuidad consolida en Nivel 3.

Redundancia y resiliencia de interconexiones

Este dominio engloba la robustez de las interconexiones del sistema: enlaces a Internet (multi-ISP), interconexión de los CPDs y conexiones con redes de terceros como SARA o el Real Observatorio (ROA para NTP). La situación actual presenta fortalezas pero también puntos de mejora:

- Enlaces a Internet multi-ISP: CERES cuenta con múltiples proveedores de Internet en ambos CPDs, con un total de 4 routers perimetrales configurados con HSRP. Esto permite entrada de tráfico por cualquiera de los ISPs. Sin embargo, actualmente la salida de Internet está “pegada” al router por el que entró el tráfico, usando la funcionalidad de auto next hop del F5. Convendría utilizar eBGP para balanceo de salida, se tiene planeado habilitarlo para lograr distribución activa de salida por múltiples ISPs. FNMT-RCM (CERES) ya posee su AS propio, lo que habilita técnicamente anunciar sus prefijos IP por varios proveedores con BGP.
- Interconexión CPD principal - CPD respaldo: Ya detallada en anteriormente, hay dos fibras diversificadas con alta capacidad. Desde el punto de vista lógico, hoy por hoy la conmutación de servicios de un CPD a otro no es completamente automática salvo para ciertos componentes. Se confía en procedimientos manuales o semiautomáticos (p.ej. activar granjas en CPD de respaldo, etc.). Esto introduce algunos retrasos en recuperación ante desastres. FNMT-RCM (CERES) aspira a un modelo activo-activo en que ambos CPDs funcionen a la par y no haya que conmutar nada en

fallo. Actualmente, la limitación principal para ello es la falta de clústeres HA en respaldo y optimizar configuraciones (firewall, F5).

- Red SARA y conexiones a Fábrica: La red SARA dispone de cuatro routers gestionados por el organismo gubernamental, con dos equipos ubicados en el CPD principal y otros dos en el CPD de respaldo. Desde los sistemas de CERES existe una extensión L2 hacia la red de Fábrica que introduce cierta dependencia de esa capa de conmutación; no obstante, en caso de caída del CPD principal, el CPD de respaldo puede seguir accediendo a los organismos públicos a través de sus dos routers de SARA.
- Sincronización horaria (ROA): Existe una interconexión dedicada con el Real Observatorio de la Armada para recibir señal horaria (NTP), con líneas tanto en el centro principal como en el centro de respaldo. En el CPD principal se alojan las centrales de tiempo y el receptor GPS, que distribuyen la hora hacia los sistemas internos, mientras que en el CPD de respaldo no existen centrales de tiempo propias aunque sí conexión redundada hacia las centrales alojadas en Cádiz. Dado que FNMT-CERES presta servicios de sellado de tiempo, el servicio de NTP se considera crítico y su disponibilidad se vigila de forma prioritaria.
- Red de gestión de equipos de red: Tras el incidente eléctrico, FNMT-RCM (CERES) se dio cuenta de que la VPN de gestión dependía del CPD principal y al caer dejó sin acceso a los equipos incluso del secundario. Por ello, se está desplegando una VPN de administración independiente en el CPD de respaldo. Esto mejora enormemente la resiliencia de la administración de la infraestructura, permitiendo gestionar el secundario incluso si el primario no está.

En general, las interconexiones tienen redundancia a nivel físico (varios ISPs, fibras duales) pero hay detalles lógicos por afinar. Actualmente, el nivel de madurez es Nivel 3 (Definido): la infraestructura está diseñada con redundancias, pero la conmutación ante fallos no es totalmente automática ni simétrica. Se dependen de ciertas acciones manuales o un único centro para algunos servicios.

3. Matriz de riesgos

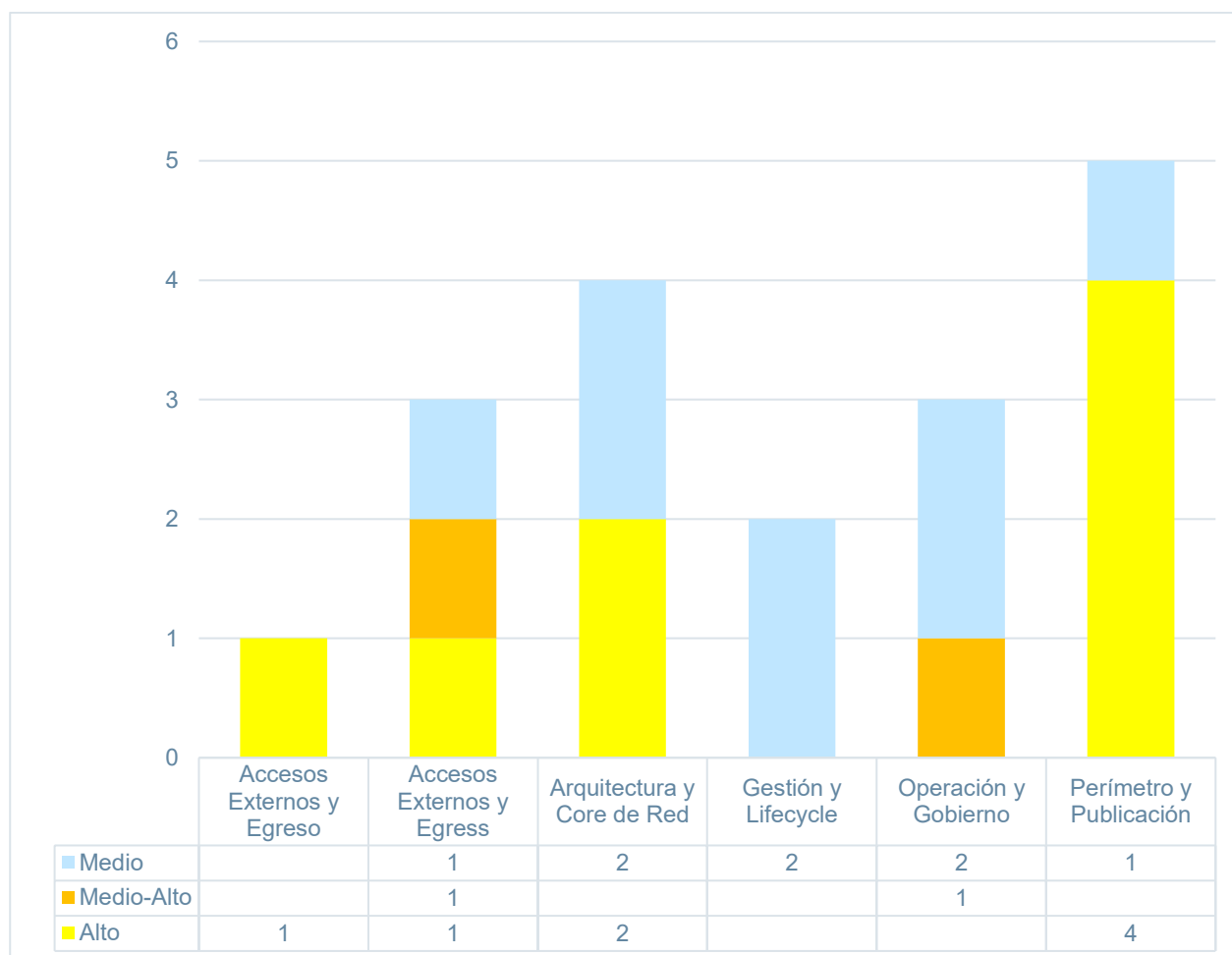
El análisis de esta torre tecnológica de FNMT-RCM (CERES) ha permitido identificar un conjunto de riesgos que pueden afectar a la disponibilidad, integridad, seguridad y continuidad del servicio.

Estos riesgos se han agrupado por capas tecnológicas y componentes críticos, considerando su impacto potencial en la operación, la recuperación ante desastres y la ciberresiliencia global del entorno.

ID	Capa	Riesgo	Descripción del riesgo	Impacto	Prob.	Nivel
RNET01	Perímetro y Publicación	HA desigual en DR	En el CPD de respaldo existen elementos stand-alone (firewalls y balanceadores) y el F5 externo opera en activo-pasivo, la publicación se concentra en ese clúster, incrementando el punto de fallo en contingencia.	Alto	Medio	Alto
RNET02	Arquitectura y Core de Red	VLANs L2 extendidas entre sedes	Persisten VLANs extendidas y dependencias L2 entre CPDs y hacia SARA o Fábrica, elevando el dominio de fallo y la complejidad operativa.	Alto	Medio	Alto
RNET03	Arquitectura y Core de Red	Core L2 y FW como default GW	Los Palo Alto actúan como gateway de las VLANs y existe core L2 donde aplica, centralizando el tránsito Este-Oeste y el punto de decisión.	Alto	Medio	Alto
RNET04	Arquitectura y Core de Red	Asimetrías por Auto Last Hop y HSRP	La salida usa HSRP entre routers de operadora, pero los F5 externos emplean Auto Last Hop para mantener simetría, si se usara HSRP "puro", la salida iría por un único operador.	Medio	Medio	Medio
RNET05	Arquitectura y Core de Red	Cuello de Fábrica (1 Gbps)	La conectividad de Fábrica opera actualmente a 1 Gbps, pudiendo convertirse en cuello de botella en determinadas rutas o servicios, si bien existe un plan en marcha para migrar esta red a 10 Gbps y alinear su capacidad con el resto de la infraestructura.	Medio	Medio	Medio
RNET06	Accesos Externos y Egress	Anti-DDoS heterogéneo	Telefónica dispone de mitigación DDoS, Colt no, se está trabajando en plataforma de mitigación, por lo que la protección actual es no homogénea.	Alto	Medio	Alto
RNET07	Accesos Externos y Egreso	Dependencia L2 hacia SARA	La conectividad SARA usa extensión L2 entre CPDs y Fábrica por lo que un problema en switches de Fábrica afecta a la red de SARA.	Alto	Medio	Alto
RNET08	Accesos Externos y Egress	Sin eBGP propio de cliente	Routing en CPD estático, BGP lo gestionan los operadores. Se anota como mejora levantar iBGP/BGP propio para no depender únicamente de ALH/HSRP en la salida; esta evolución se encuentra ya en proyecto asociado a la implantación actual de Telefónica.	Medio-Alto	Medio	Medio-Alto

RNET09	Accesos Externos y Egress	Balanceo geográfico basado en F5 sin GSLB DNS externo	Aunque los cuatro routers de operadora trabajan en modo activo/activo/activo/activo y el balanceo geográfico de servicios entre CPDs se realiza en la plataforma F5, no se explotan mecanismos de GSLB en DNS externo (por ejemplo, en Akamai) para distribuir la entrada a nivel de resolución de nombres. Esto concentra la lógica de reparto geográfico en la capa de balanceo y limita la granularidad de estrategias avanzadas de distribución y failover por región.	Medio	Medio	Medio
RNET10	Perímetro y Publicación	Servicios directos sin Akamai/WAF	La mayoría de servicios no pasan por Akamai (CDN/WAF) y entran directos al CPD, hay dominios publicados directamente.	Alto	Medio	Alto
RNET11	Perímetro y Publicación	“Chokepoint” en F5 externo	La publicación de servicios se concentra en el clúster F5 externo, que además es el L3 de entrada para accesos externos.	Alto	Medio	Alto
RNET12	Perímetro y Publicación	Tráfico directo sin inspección L7	El tráfico directo (sin Akamai) no se inspecciona de forma completa en L7 en el perímetro Fortinet: al no romperse la sesión TLS en esa capa, solo se realiza inspección profunda sobre tráfico HTTP o no cifrado. La inspección L7 principal sobre tráfico cifrado ocurre tras el balanceo, lo que reduce la capacidad de detección temprana en el perímetro para ciertos patrones de ataque.	Medio-Alto	Medio	Alto
RNET13	Perímetro y Publicación	WAF interno genérico	El WAF interno aplica controles genéricos (“se deniega lo obvio”), sin patrones específicos por aplicación.	Medio	Medio	Medio
RNET14	Operación y Gobierno	Gestión por CLI, NDFC no adoptado	La administración de switches se realiza por CLI, existe Nexus Dashboard Fabric Controller pero no se usa por falta de tiempo para formar al equipo.	Medio	Alto	Medio-Alto
RNET15	Operación y Gobierno	Volumen y saneamiento de reglas	~900 reglas en el FW interno y ~200 en el Fortinet externo. Aunque se está implantando un proceso de revisión periódica de reglas supervisado por las auditorías internas de ASIN, al encontrarse todavía en fase de consolidación persiste el riesgo de que, si no se mantiene un saneamiento continuo y sistemático, puedan permanecer reglas obsoletas en la configuración.	Medio	Medio	Medio
RNET16	Operación y Gobierno	Carga operativa elevada	La tramitación y aplicación de reglas por servicio supone alta carga para el equipo y puede alargar provisiones o cambios.	Medio	Medio	Medio
RNET17	Gestión y Lifecycle	NX-OS fuera de soporte	Nexus con NX-OS 9.3(10) se indica fuera de soporte, hay proyecto para migrar a 10.4(4) (en soporte).	Medio	Medio	Medio
RNET18	Gestión y Lifecycle	VPN de gestión DR en despliegue	La VPN para administración. DR está en fase de despliegue, por lo que la operativa de gestión en contingencia aún no está cerrada.	Medio	Medio	Medio

3.1. Resumen de riesgos agrupados por nivel de riesgo



3.2. Top de riesgos

Top de riesgos priorizados por impacto en disponibilidad, publicación, continuidad inter-CPD y exposición perimetral:

1. RNET11 - “Chokepoint” en F5 externo (Alto)

Motivo de priorización: La publicación de servicios (Internet y SARA) se concentra en el clúster F5 externo, que además actúa como L3 de entrada. Un fallo de clúster/configuración impactaría la entrada global de tráfico, afectando disponibilidad y publicación.

2. RNET01 - HA desigual en DR (Alto)

Motivo de priorización: En el CPD de respaldo hay appliances en stand-alone (FW y F5 interno) y el F5 externo no es activo-activo entre sedes, degradando la resiliencia en conmutación y elevando el riesgo en contingencia inter-CPD.

3. RNET10 - Servicios directos sin Akamai/WAF (Alto)

Motivo de priorización: Una parte relevante de servicios entra directa al CPD fuera de Akamai/WAF, ampliando la superficie de ataque L7 y la dependencia de controles locales para exposición perimetral.

4. **RNET12 - Tráfico directo sin inspección L7 (Alto)**

Motivo de priorización: El tráfico que no pasa por Akamai no se inspecciona en L7 en el perímetro Fortinet; la inspección profunda ocurre tras el balanceo. Incrementa el riesgo de exploits a aplicación antes de los controles internos.

5. **RNET06 - Anti-DDoS heterogéneo (Alto)**

Motivo de priorización: Mitigación DDoS solo en una operadora (la otra sin protección) y plataforma de mitigación aún en despliegue; persiste riesgo de saturación volumétrica previa a balanceadores/perímetro, afectando disponibilidad externa.

6. **RNET02 - VLANs L2 extendidas entre sedes (Alto)**

Motivo de priorización: El L2 extendido incrementa el dominio de fallo y complica la conmutación inter-CPD (bucles, tormentas, asimetrías), con impacto directo en continuidad y estabilidad este-oeste.

7. **RNET07 - Dependencia L2 hacia SARA (Alto)**

Motivo de priorización: La conectividad SARA depende de extensión L2 y de switches de Fábrica; un problema en esa capa impacta la interconexión con AA.PP., afectando servicios publicados hacia SARA.

8. **RNET03 - Core L2 y FW como default GW (Alto)**

Motivo de priorización: Los Palo Alto actúan como gateway de VLANs y existe core L2 donde aplica, centralizando tránsito este-oeste y la decisión de forwarding. Aumenta el punto de concentración (rendimiento/aislamiento) y la sensibilidad a fallos de perímetro.

4. Niveles de Madurez

4.1. Metodología de valoración y lectura de resultados

El nivel de madurez describe el grado de adopción sistemática de prácticas, controles y capacidades que sostienen la resiliencia, la calidad operativa y la mejora continua. No es una certificación ni un juicio de valor, sino una herramienta de gestión para priorizar el tránsito del AS-IS al TO-BE/TO-DO.

La valoración se ha realizado mediante juicio experto sustentado en evidencias obtenidas de:

- Entrevistas estructuradas con operación de red y seguridad y arquitectura.
- Documentación técnica aportada (diagramas, parámetros, procedimientos).
- Inferencias controladas cuando no hubo evidencia directa y era necesario completar el análisis.

Para estructurar la evaluación, nos apoyamos en un modelo de madurez adaptado al dominio de comunicaciones, networking y seguridad perimetral. Como se indicó, utilizamos cinco niveles:

- Nivel 1: Básico (Inicial) - ad hoc y reactivo
- Nivel 2: Fundamental (Control inicial)
- Nivel 3: Estandarizado (Definido y consistente)
- Nivel 4: Avanzado (Gestionado proactivamente)
- Nivel 5: Óptimo (Automatizado y resiliente)

Para esta torre tecnológica, y con el objetivo de no mezclar capacidades con finalidades, métricas y riesgos distintos, se valoran 5 dominios:

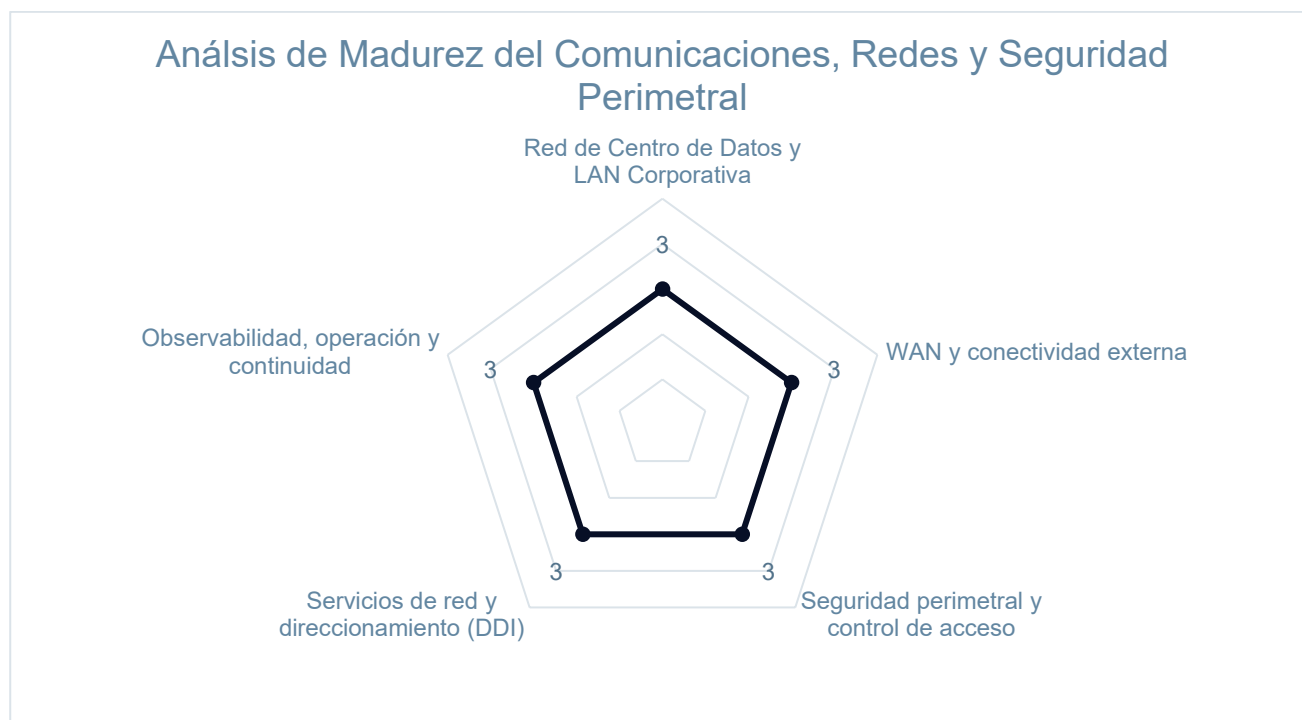
1. **Red de Centro de Datos y LAN corporativa:** (conmutación L2 Y L3, segmentación (EVPN-VXLAN o VLAN), enrutamiento interno, redundancia y alta disponibilidad intra-site, balanceadores/ADC locales).
2. **WAN y conectividad externa:** (interconexión entre sedes y CPD, MPLS O SD-WAN, enlaces a proveedores (ISP), BGP, redundancia física y lógica, acceso a nubes/terceros).
3. **Seguridad perimetral y control de acceso:** (NGFW, IPS E IDS, VPN DE ACCESO REMOTO (RA), microsegmentación y macrosegmentación, WAF, anti-DDoS y proxy cuando aplica, políticas y rule-base, gestión de parches/firmware).
4. **Servicios de red y direccionamiento (DDI):** (DNS, DHCP, IPAM, NTP, plan de direccionamiento, trazabilidad de cambios, integridad/consistencia entre sedes y dominios).
5. **Observabilidad, operación y continuidad:** (monitorización y telemetría de red, flujos de red (sFlow o NetFlow), syslog, CMDB e inventario, backups de configuración, automatización/IaC, gestión de cambios, pruebas de conmutación y DR y procedimientos operativos).

La separación en dominios facilita asignar pesos y evidencias específicas, mejora la comparabilidad entre áreas y permite priorizar con precisión el paso del **AS-IS** al **TO-BE/TO-DO**.

Cada dominio se desglosa en sub-bloques evaluables (procesos, tecnología, gobierno/seguridad, automatización y evidencias de prueba) para asegurar una lectura homogénea y auditable de resultados.

4.2. Evaluación de la madurez de Comunicaciones, Redes y Seguridad perimetral

Pasamos a analizar cada dominio identificado. En cada uno se describe primero la Situación Actual (hechos observados o asumidos a partir de entrevistas y documentación) y, a continuación, se asigna un Nivel de Madurez con su justificación y palancas de avance hacia el siguiente nivel.



4.2.1 Red de Centro de Datos y LAN corporativa

Situación Actual

La topología de red de los CPD se describe de forma jerárquica (core, distribución y acceso) y con redundancia en equipos y enlaces en los tramos críticos. La segmentación se articula mediante VLAN Y VRF y enrutamiento L3 en la capa de distribución o core. Se dispone de mecanismos de alta disponibilidad intra-site (p. ej., protocolos de redundancia de puerta de enlace y agregación de enlaces). La operación y los cambios se registran en el gestor corporativo, con ventanas de mantenimiento y coordinación con los equipos implicados. No consta, en la evidencia revisada, un plan homogéneo de pruebas periódicas de resiliencia (fallo de enlace o nodo) ni post-check estandarizado tras cambios, y persisten áreas con dependencia L2 que sería deseable acotar.

Nivel de Madurez: Nivel 3 - Estandarizado (Definido y consistente)

Arquitectura ordenada, segmentación sistemática y HA intra-site justifican el nivel.

Condiciones de salto a Nivel 4: pruebas de resiliencia calendarizadas y registradas, post-checks automatizados tras cambio, plantillas y control de configuración (IaC) para uniformidad y reducción de deriva.

4.2.2 WAN y conectividad externa

Situación Actual

La interconexión entre sedes y CPD se apoya en enlaces redundantes y enrutamiento dinámico cuando aplica. El acceso a Internet y a redes administrativas (p. ej., SARA) se realiza con políticas de preferencia/filtrado y coordinación operativa con proveedores bajo ANS/SLA. Existen mantenimientos planificados y mecanismos de notificación. No se evidencian, de forma sistemática, pruebas de conmutación por dominio (Internet y Red SARA e inter-CPD) con medición formal de RTO y registro de resultados, en despliegues con SD-WAN, la estandarización de perfiles por tipología de sede está en evolución.

Nivel de Madurez: Nivel 3 - Estandarizado

Diseño redundante y enrutamiento dinámico correctamente implementados sustentan el nivel.

Condiciones de salto a Nivel 4: orquestación de cambios WAN con plantillas, batería de drills de failover inter-CPD e Internet y SARA con métricas y actas, integración de SLO de red (latencia, jitter, pérdida) en cuadros de mando operativos.

4.2.3 Seguridad perimetral y control de acceso

Situación Actual

El perímetro se apoya en firewalls de nueva generación en alta disponibilidad con políticas por zonas. El acceso remoto corporativo está protegido mediante autenticación fuerte (MFA) y perfiles por rol. Para la publicación de aplicaciones se utilizan servicios específicos (p. ej., reverse proxy/WAF) y, en función de criticidad, medidas anti-DDoS. La gestión de parches y firmware se realiza en ventanas programadas. No se ha aportado un cuadro consolidado de cumplimiento de parcheo ni métricas de rule-base (envejecimiento, hit-count, IPS obsoletos) que permitan valorar la higiene de forma cuantitativa, la microsegmentación a nivel de carga es parcial.

Nivel de Madurez: Nivel 3 alto - Estandarizado

Controles perimetrales robustos y publicación protegida justifican 3 alto.

Condiciones de salto a Nivel 4-5: gestión de configuración declarativa (plantillas o policy-as-code) para FW, WAF y VPN, limpieza continua de rule-base con KPIs, microsegmentación sistemática en cargas críticas e informes periódicos de postura y cumplimiento.

4.2.4 Servicios de red y direccionamiento (DDI)

Situación Actual

Los servicios DNS y DHCP están centralizados y replicados, con separación de ámbitos internos y externos. El direccionamiento es mayoritariamente estático y se apoya en documentación y en la información obtenida a través de la herramienta de descubrimiento Discovery, que en el entorno de producción permite tener una referencia del direccionamiento dado de alta. No se dispone de un IPAM formal como tal más allá de esta funcionalidad de descubrimiento. Se ejecutan copias de seguridad de configuración de los dispositivos y de las zonas, aunque no se han aportado evidencias recurrentes de restores verificados ni de la integración completa del ciclo de cambios DDI con inventario.

Nivel de Madurez: Nivel 3 - Estandarizado

DDI consistente y replicado avala el nivel.

Condiciones de salto a Nivel 4: reconciliación IPAM-CMDB al 100 % con metadatos obligatorios, validaciones automáticas pre/post cambio y pruebas de restore calendarizadas con evidencias.

4.2.5 Observabilidad, operación y continuidad

Situación Actual

La red está monitorizada con métricas de estado y rendimiento, logs centralizados y, donde aplica, flujos de red que alimentan cuadros de mando y alertas. Existe una herramienta de descubrimiento (Discovery) en uso que actúa como CMDB de facto para el entorno de producción. Se realizan copias de seguridad de configuración de red, si bien la adopción de automatización/IaC (plantillas, validaciones y pruebas) es dispar entre dominios. Se ejecutan pruebas de conmutación (DR/failover) con periodicidad variable según ámbito, con actas, aunque no siempre incluyen verificación end-to-end de reconexión de aplicaciones, usuarios y tiempos formalmente medidos.

Nivel de Madurez: Nivel 3 - Estandarizado

Buen nivel de visibilidad y operación.

Condiciones de salto a Nivel 4: pipelines de validación (previas y posteriores al cambio), SLO/KPI por dominio integrados con alertado, CMDB fidedigna por descubrimiento o autoalimentación y runbooks ejecutables para DR con medición comparativa de RTO/RPO.

4.2.6 Notas de interpretación y cierre

- Cada dominio hereda la escala de cinco niveles y se ha valorado conforme a los sub-bloques definidos (Tecnología y Diseño, Gobierno y Seguridad, Operación y Observabilidad, Automatización/IaC, Evidencias de prueba).
- Las calificaciones se basan en la evidencia disponible. En aquellos aspectos sin evidencia directa se han adoptado conclusiones conservadoras.

5. Conclusiones

El entorno de FNMT-RCM (CERES) se apoya en una base física robusta y actualizada y presenta, en conjunto, una madurez mayoritariamente de Nivel 3 (Estandarizado) en los cinco dominios analizados. La arquitectura de DC/LAN es ordenada y redundada, la WAN está bien dimensionada y con rutas alternativas, el perímetro aplica controles NGFW/WAF consistentes, DDI está centralizado y replicado, y la operación dispone de monitorización y registros.

No obstante, no se alcanzan criterios de Nivel 4 en ningún dominio con la evidencia revisada: faltan pruebas periódicas y registradas de resiliencia y DR end-to-end, automatización/IaC y plantillas para cambios repetibles, post-checks y validación sistemática tras cambio, SLO/KPI operativos integrados en cuadros de mando, limpieza continua de rule-base y reconciliación completa CMDB e IPAM. Con estas palancas institucionalizadas y evidenciadas, el entorno podría evolucionar de forma consistente hacia Nivel 4 (Gestionado) en próximas evaluaciones.

5.1. Arquitectura de red

- Topología spine-leaf implementada correctamente, con redundancia de enlaces 40 Gbps entre spines y leafs.
- Existencia de dos CPDs (principal y respaldo) interconectados por fibras DWDM diversificadas. Funcionando en modo activo-pasivo, con elementos no redundados en el secundario.
- Enlaces de Internet redundados en ambos Centro de datos. COLT en el CPD de respaldo con un ancho de banda de 2Gbps y Telefónica en el CPD principal con 1Gbps. Ocupación máxima de un 60% del ancho de banda disponible.
- Routing estático en la LAN del Centro de datos.
- VLANs extendidas entre Centro de datos.

5.2. Balanceo de carga

- Infraestructura F5 virtualizada (2 en principal y 1 en respaldo).
- Clústeres externos e internos bien configurados, con NATs diferenciados por entorno (Internet, SARA, interno).
- El balanceo global entre CPDs se realiza a través de la plataforma F5, que reparte servicios entre el CPD principal y el de respaldo; no obstante, esta capacidad depende de un único clúster extendido y presenta margen de mejora en términos de resiliencia y gobierno centralizado de la distribución geográfica.
- Las funciones L7 (como redirección por URL) se delegan a Apache, desaprovechando las capacidades del F5.

5.3. Seguridad y segmentación

- Fortinet perimetrales (Internet y SARA) y Palo Alto internos (entre DMZ y backend).
- Buenas prácticas: separación por zonas, registro completo, política deny all, doble control de cambios.
- Transición progresiva a reglas L7 con App-ID en la capa interna.
- Políticas de Fortinet basadas solo en IP y puerto (sin inspección de aplicación).
- WAF activo en Akamai y parcialmente en F5 internos.
- Proyecto de Prolexic (Akamai) en marcha, pero no cubre aún todos los flujos.

5.4. Gestión operativa y seguridad

- Uso obligatorio de SafeGuard (PAM) para accesos privilegiados.
- Accesos nominales y trazables, grabación de sesiones y control de identidades.
- Cuentas Windows individuales, cuentas Linux genéricas con trazabilidad.

5.5. Políticas de gestión y operación

- Administración manual vía CLI en switches Nexus, aunque existe Nexus Dashboard Fabric Controller sin desplegar.
- Proceso formal de doble control en cambios de FW (segregación de funciones).
- Falta de automatización y limpieza sistemática de reglas.
- Elevada carga de trabajo en altas y modificaciones.
- Ciclo semestral de parcheo más aplicación inmediata de CVEs críticas.
- Seguimiento de vulnerabilidades SOC interno. Sonda Nessus.

5.6. DNS

- DNS externo gestionado por Akamai (CDN y redundancia global).
- DNS interno BIND redundado por CPD con alta disponibilidad.

5.7. Resumen global

FNMT-RCM (CERES) cuenta con una base de infraestructura sólida, resiliente y tecnológicamente actualizada en el plano físico, pero con dependencias lógicas y operativas que reducen la simetría y automatización global del entorno.

Los esfuerzos recientes (refuerzo post-incidente, despliegue PAM, integración Akamai/Prolexic) evidencian un avance constante hacia niveles de madurez superiores.

El reto principal es completar la transición hacia una arquitectura L3 segmentada, activa-activa, automatizada y con seguridad L7 plena, apoyada en herramientas de gestión centralizada y políticas más dinámicas.